

PLAN DE
CYBER THREAT
INTELLIGENCE

Diseño, gobierno, operación y mejora continua del programa CTI

Organización	[RataSoft SPA]
Propietario	[CISO / RESPONSABLE CTI]
Versión y fecha	[V0.1] · [31-07-2026]
Clasificación	[USO INTERNO / CONFIDENCIAL]



0 Control del documento

Identificación y control de versiones

Campo	Contenido
Título del documento	Plan de Cyber Threat Intelligence
Código documental	[CTI-PLN-001]
Propietario	[CISO / Responsable CTI]
Aprobador	[Comité de Ciberseguridad / Director]
Clasificación	[Uso Interno / Confidencial]
Ciclo de revisión	[Semestral / anual]
Próxima revisión	[31-01-2027]
Marco principal	CTI-CMM v1.3 / NIST SP 800-150 / MITRE ATT&CK

Historial de cambios

Versión	Fecha	Autor	Descripción del cambio	Aprobación
0.1	[28-07-2026]	[Arnoldo Treviño Ceja]	Borrador inicial	Pendiente
1.0	[31-07-2026]	[Arnoldo Treviño ceja]	Versión aprobada	Comité de Ciberseguridad / Director]

Firmas de aprobación

Rol	Nombre y cargo	Campo	Valor
Elaborado por	Arnoldo Treviño Ceja/ Analista CTI / Ciberinteligencia	Fecha	[28-07-2026]
Revisado por	Isaac Martínez Cossio / CISO / Responsable CTI	Fecha	[30-07-2026]
Aprobado por	María Magdalena González Álvarez / CEO / Director General	Fecha	[31-07-2026]

0.1 Cómo utilizar esta plantilla

Esta plantilla separa el contenido doctrinal, los campos obligatorios y los ejemplos. Su objetivo es facilitar un plan ejecutable, no producir un documento meramente descriptivo. El programa debe demostrar cómo la inteligencia modifica decisiones, controles, prioridades y exposición al riesgo. (*DeBolt et al., 2026; Pace, 2018*)

Criterios de calidad

- Todos los PIR y KIQ tienen un stakeholder, una decisión asociada y un plazo.
- Cada fuente responde a un requerimiento; no se contratan feeds sin caso de uso.
- Los productos CTI tienen audiencia, formato, frecuencia, SLA y curso de acción esperado.
- Las integraciones con SOC, IR, vulnerabilidades, riesgo y terceros están definidas.
- Los indicadores miden resultados y cambio de decisiones, no solo volumen de reportes.
- El roadmap tiene responsables, costos, dependencias, evidencia y criterios de cierre.

Tabla de contenido

0 Control del documento	2
Identificación y control de versiones	2
Historial de cambios	2
Firmas de aprobación.....	2
0.1 Cómo utilizar esta plantilla	3
Criterios de calidad antes de aprobar	3
Tabla de contenido.....	4
1.1 Resumen ejecutivo.....	6
1.2 Contexto y justificación del programa	7
1.3 Objetivos.....	11
1.4 Alcance y exclusiones.....	11
1.5 Principios rectores	12
2.1 Estructura de gobierno	13
2.2 Modelo operativo.....	13
2.3 Mapa de stakeholders	14
2.4 Matriz RACI.....	15
2.5 Equipo, roles y competencias	15
3.1 Evaluación de madurez	17
3.2 Requerimientos de inteligencia.....	18
3.3 Perfil de amenazas organizacional.....	21
3.4 Priorización de requerimientos y casos de uso	23
4.1 Modelo de ciclo CTI.....	25
4.2 Plan de recolección.....	26
4.3 Catálogo y evaluación de fuentes	29
4.4 Procesamiento, enriquecimiento y calidad.....	30
4.5 Análisis, confianza y control de sesgos	31
5.1 Catálogo de productos CTI.....	33
5.2 Plantilla mínima de producto de inteligencia.....	34
5.3 Matriz de diseminación.....	34
5.4 Gestión de solicitudes de información — RFI.....	35
5.5 Feedback y ciclo de mejora	35
6.1 Integración con SOC y detección	37
6.2 Integración con respuesta a incidentes y crisis	37
6.3 Integración con vulnerabilidades y superficie de ataque	38
6.4 Integración con riesgo, arquitectura, terceros y fraude	38
6.5 Threat-informed defense.....	39
7.1 Arquitectura lógica de referencia.....	40
7.2 Requisitos funcionales de plataforma	40
7.3 Gobierno de datos CTI.....	41
7.4 Proveedores, licencias y evaluación	41

8.1 Modelo de medición	43
8.2 Scorecard ejecutivo.....	43
8.3 Revisión de madurez y mejora.....	44
9.1 Roadmap de implementación.....	45
9.2 Plan de recursos y presupuesto	46
9.3 Riesgos del programa	46
9.4 Dependencias y supuestos	47
9.5 Criterios de aprobación y entrada en operación.....	48
Aprobación final	48
A.1 Registro maestro de PIR y KIQ	48
A.2 Formulario de RFI	48
A.3 Evaluación de fuente de inteligencia	49
A.4 Perfil de actor o campaña.....	49
A.5 Plantilla de alerta rápida.....	50
A.6 Registro de IOC y ciclo de vida	50
A.7 Registro de acciones derivadas de CTI.....	50
A.8 Checklist de revisión de producto	50
A.9 Autoevaluación CTI-CMM resumida	51
A.10 Glosario mínimo	51
Referencias	52

01

Dirección estratégica

Define el propósito, el valor para el negocio y los límites del programa.

1.1 Resumen ejecutivo

Instrucción

Resume en una página: problema, exposición, objetivo del programa, decisiones que habilitará, capacidades prioritarias, inversión y resultados esperados.

RataSoft SpA es una empresa dedicada al desarrollo de software, integración de APIs y operación de servicios cloud para clientes de sectores altamente regulados, cuya estrategia de crecimiento contempla ampliar su presencia en mercados con mayores exigencias de seguridad y cumplimiento. Sin embargo, el crecimiento del negocio ha superado la madurez de sus capacidades de ciberseguridad, especialmente en materia de Cyber Threat Intelligence (CTI), donde actualmente no existe un programa formal que permita identificar, analizar y anticipar amenazas relevantes para la organización y sus clientes. Esta situación incrementa la incertidumbre en la toma de decisiones estratégicas y operativas frente a riesgos como ataques a la cadena de suministro, compromiso de credenciales, explotación de vulnerabilidades, filtración de secretos, abuso de APIs y campañas de phishing dirigidas.

La exposición de RataSoft es especialmente significativa debido a la naturaleza de sus activos críticos, entre los que destacan los repositorios de código fuente, los pipelines de integración y despliegue continuo (CI/CD), las credenciales privilegiadas, los entornos cloud y los componentes reutilizables utilizados por múltiples clientes. Un compromiso de cualquiera de estos activos podría afectar simultáneamente a organizaciones como Banco Andino Digital y Clínica Aurora, generando impactos contractuales, regulatorios, operacionales y reputacionales, además de convertir a RataSoft en un potencial vector de ataques de cadena de suministro.

Con el propósito de reducir esta exposición, el presente Plan de Cyber Threat Intelligence propone la implementación de un programa CTI alineado con los objetivos estratégicos de la organización y orientado a disminuir la incertidumbre mediante la producción de inteligencia accionable para los distintos niveles de decisión. El programa integrará información proveniente de fuentes internas y externas para identificar actores de amenaza, campañas, vulnerabilidades explotadas activamente, indicadores de compromiso y tácticas, técnicas y procedimientos (TTP) relevantes para el contexto de RataSoft, transformando estos datos en conocimiento útil para la gestión del riesgo.

El programa permitirá respaldar decisiones relacionadas con el endurecimiento de los procesos DevSecOps, la protección de repositorios y pipelines, la priorización contextualizada de vulnerabilidades, el fortalecimiento de los controles de identidad y acceso, la mejora de las capacidades de detección y respuesta del SOC/MSSP, la gestión de riesgos asociados a terceros y contratistas, así como la comunicación oportuna con clientes regulados ante amenazas o incidentes que puedan afectar sus servicios.

Como capacidades prioritarias se establecerán un modelo formal de requerimientos de inteligencia (PIR y KIQ), un proceso estructurado de recolección y análisis de información, un catálogo de productos CTI adaptado a cada stakeholder, la integración de inteligencia con los procesos de gestión de vulnerabilidades, respuesta a incidentes, DevSecOps y gestión de riesgos, además de un conjunto de

métricas que permitan evaluar el impacto del programa sobre la reducción de la exposición y la mejora en la toma de decisiones.

Considerando las restricciones de recursos existentes en la organización, la implementación se realizará de manera progresiva, aprovechando las capacidades ya disponibles como el MSSP, las herramientas de AppSec, GitHub Enterprise, AWS, los registros de auditoría y las fuentes OSINT, priorizando inversiones de alto impacto y bajo costo antes de incorporar capacidades adicionales. Este enfoque permitirá maximizar el retorno de la inversión y acelerar la madurez del programa sin afectar la continuidad operacional.

Como resultado esperado, RataSoft contará con una capacidad permanente de Cyber Threat Intelligence capaz de anticipar amenazas relevantes, priorizar riesgos de acuerdo con el contexto del negocio, fortalecer la protección de sus activos críticos y mejorar la resiliencia frente a ataques dirigidos. Asimismo, el programa contribuirá a incrementar la confianza de los clientes, respaldar el cumplimiento de los compromisos contractuales y proporcionar información confiable para la toma de decisiones estratégicas, tácticas y operacionales, fortaleciendo la postura de ciberseguridad de la organización y apoyando su objetivo de crecimiento en sectores regulados.



La inteligencia solo crea valor cuando modifica una decisión, una prioridad o un control.

Figura 1. Cadena de valor del programa CTI. Elaboración propia, adaptada de CTI-CMM y del ciclo de inteligencia.

1.2 Contexto y justificación del programa

CTI debe contextualizar capacidades, intención, motivaciones, oportunidades y TTP de adversarios relevantes para apoyar a los responsables de proteger la organización y reducir riesgo. Su valor depende de la colaboración con stakeholders y de la alineación con objetivos y resultados de negocio. (DeBolt et al., 2026)

Dimensión	Situación actual	Riesgo / impacto	Decisión requerida
Amenazas prioritarias	RataSoft carece de un programa formal de CTI que permita identificar, priorizar y anticipar amenazas específicas para su negocio. La organización enfrenta un escenario de riesgo caracterizado por ataques a la cadena de suministro de software, phishing dirigido a desarrolladores y contratistas, compromiso de credenciales, filtración de información secreta o de	La materialización de estas amenazas puede provocar comprometer el código fuente, inserción de software malicioso en los pipelines CI/CD, acceso no autorizado a entornos cloud, afectación de clientes regulados, incumplimiento contractual, pérdida de confianza, sanciones regulatorias y daños financieros y reputacionales derivados de un incidente de cadena de suministro	Implementar un programa CTI orientado a identificar, monitorear y priorizar continuamente las amenazas más relevantes para RataSoft, integrando inteligencia estratégica, operacional y táctica que permita fortalecer los controles preventivos, mejorar las capacidades de detección y apoyar decisiones de seguridad basadas en el contexto de amenazas y riesgo empresarial.

Dimensión	Situación actual	Riesgo / impacto	Decisión requerida
	carácter confidencial, abuso de APIs, explotación de vulnerabilidades en componentes de software y campañas de typo-squatting contra dependencias utilizadas en el proceso de desarrollo.		
Activos críticos / crown jewels	Los activos más críticos de RataSoft incluyen los repositorios de código fuente en GitHub Enterprise, los pipelines CI/CD, las cuentas y servicios cloud en AWS, las bases de datos de clientes, secretos y credenciales privilegiadas (API Keys, Secret Keys, tokens OAuth, Personal Access Tokens, certificados y credenciales de integración y la documentación técnica en Confluence. Estos activos soportan el desarrollo, despliegue y operación de soluciones para clientes regulados, pero presentan brechas de seguridad como protección inconsistente de repositorios, secretos heredados, retención limitada de registros y controles desiguales sobre contratistas y cuentas de servicio.	El tener comprometidos estos activos podría permitir la exfiltración o manipulación de código fuente, la inserción de software malicioso en la cadena de suministro, el acceso no autorizado a datos sensibles y credenciales, la interrupción de servicios críticos y el incumplimiento de obligaciones contractuales y regulatorias, afectando directamente la confianza de los clientes y la continuidad del negocio.	Priorizar los crown jewels dentro del programa CTI mediante monitoreo continuo, inteligencia específica sobre amenazas dirigidas a repositorios, identidades privilegiadas, pipelines CI/CD y entornos cloud, integrando dicha inteligencia con DevSecOps, gestión de vulnerabilidades, SOC e IR Incident Response para orientar la protección y respuesta sobre los activos de mayor criticidad.
Exposición externa	RataSoft mantiene una superficie de ataque expuesta compuesta por dominios y subdominios públicos, repositorios GitHub, paquetes de software, infraestructura cloud y presencia de colaboradores en plataformas públicas como LinkedIn. Adicionalmente, el acceso de contratistas y la publicación de información técnica incrementan las oportunidades de reconocimiento por parte	La exposición pública puede facilitar campañas de phishing dirigido, robo de credenciales, abuso de marca, explotación de vulnerabilidades conocidas, ataques de dependency confusion y typo-squatting, así como compromisos de la cadena de suministro que afecten tanto a RataSoft como a sus clientes regulados. Esto incrementa la probabilidad de incidentes con impacto operacional, contractual y reputacional.	Establecer capacidades permanentes de monitoreo y análisis de la superficie de ataque externa mediante fuentes OSINT e inteligencia de amenazas, priorizando la vigilancia de dominios, repositorios, paquetes, certificados, menciones de la organización, credenciales expuestas y posibles indicadores de abuso. La información obtenida deberá integrarse con el programa CTI para apoyar decisiones de endurecimiento de controles, gestión de vulnerabilidades y protección de la cadena de suministro.

Dimensión	Situación actual	Riesgo / impacto	Decisión requerida
	de actores maliciosos. Actualmente no existe un monitoreo continuo de la exposición externa ni de indicadores de abuso relacionados con la organización, sus activos o su marca.		
Incidentes y pérdidas	RataSoft ha experimentado incidentes e indicadores de compromiso relacionados con la exposición de credenciales, campañas de phishing dirigidas, hallazgos de secretos y credenciales privilegiadas (API Keys, Secret Keys, tokens OAuth, Personal Access Tokens, certificados y credenciales de integración en repositorios, intentos de abuso de la cadena de suministro y exposición de credenciales de terceros. Aunque estos eventos fueron contenidos, evidencian la ausencia de un proceso sistemático para correlacionar incidentes, identificar tendencias y transformar la información obtenida en inteligencia para prevenir eventos futuros.	La recurrencia de estos incidentes incrementa la probabilidad de comprometer activos críticos, afectar la continuidad de los servicios, generar pérdidas económicas por respuesta y recuperación, incumplimientos contractuales con clientes regulados y daños reputacionales que podrían afectar la competitividad y el crecimiento del negocio.	Incorporar el análisis de incidentes como una fuente permanente del programa CTI, integrando la información proveniente del SOC, Incident Response, DevSecOps y proveedores de seguridad para identificar patrones, campañas, TTP y actores de amenaza, permitiendo fortalecer los controles preventivos y mejorar la capacidad de anticipación y respuesta de la organización.
Regulación y obligaciones	RataSoft presta servicios de desarrollo de software y operación de soluciones para clientes de sectores regulados, por lo que debe cumplir compromisos contractuales y marcos de seguridad como ISO 27001 y SOC 2 Tipo II, además de requisitos relacionados con la protección de datos personales y la gestión segura de la cadena de suministro. Actualmente no existe una capacidad formal de CTI que apoye de manera continua la identificación de amenazas que puedan comprometer el	La falta de inteligencia sobre amenazas relevantes puede derivar en incumplimientos regulatorios y contractuales, exposición de información sensible, sanciones, pérdida de certificaciones, incumplimiento de acuerdos de nivel de servicio (SLA) y deterioro de la confianza de clientes estratégicos, afectando la continuidad del negocio y las oportunidades de crecimiento en mercados regulados.	Integrar el programa CTI con las funciones de gestión de riesgos, cumplimiento, seguridad de la información y gestión de terceros, de manera que la inteligencia obtenida permita anticipar amenazas con impacto regulatorio, priorizar acciones de mitigación y respaldar el cumplimiento continuo de obligaciones legales, normativas y contractuales.

Dimensión	Situación actual	Riesgo / impacto	Decisión requerida
	cumplimiento de estas obligaciones.		
Dependencias de terceros	RataSoft depende de proveedores cloud, plataformas de desarrollo, componentes de software de código abierto, servicios de seguridad administrada (MSSP), contratistas y otras integraciones externas para desarrollar, desplegar y operar sus soluciones. Esta dependencia incrementa la superficie de ataque, especialmente ante vulnerabilidades en componentes de terceros, compromiso de proveedores o accesos privilegiados de contratistas.	Un incidente que afecte a un tercero puede comprometer la disponibilidad, integridad o confidencialidad de los servicios de RataSoft, facilitar ataques a la cadena de suministro, provocar filtración de información, interrupciones operativas, incumplimientos contractuales y afectar directamente a clientes regulados.	Incorporar la inteligencia sobre riesgos de terceros dentro del programa CTI mediante el monitoreo continuo de amenazas asociadas a proveedores críticos, componentes de software, servicios cloud y contratistas, integrando esta información en los procesos de gestión de riesgos de terceros, evaluación de proveedores, gestión de vulnerabilidades y respuesta a incidentes para priorizar acciones preventivas.
Procesos críticos del negocio	Los procesos de desarrollo seguro, integración continua (CI/CD), despliegue de aplicaciones, soporte a clientes y operación de plataformas cloud son esenciales para la prestación de servicios de RataSoft. Una interrupción o alteración de estos procesos impactaría directamente la entrega de software y el cumplimiento de compromisos con clientes.	La indisponibilidad o manipulación de procesos críticos puede retrasar entregas, afectar la continuidad operacional, generar incumplimientos contractuales y pérdidas económicas.	Priorizar la inteligencia de amenazas sobre los procesos críticos del negocio para anticipar riesgos que afecten la continuidad operativa y orientar la protección de los servicios esenciales.
Objetivos estratégicos del negocio	La estrategia de RataSoft contempla consolidar su crecimiento en sectores regulados mediante el desarrollo de soluciones de software seguras y confiables. Esto requiere fortalecer la postura de ciberseguridad y demostrar capacidades de gestión proactiva de amenazas.	La ocurrencia de incidentes relevantes puede afectar la confianza de clientes actuales y limitar nuevas oportunidades comerciales, especialmente en sectores con altas exigencias de seguridad.	Alinear el programa CTI con los objetivos estratégicos del negocio para que la inteligencia producida apoye decisiones que reduzcan riesgos, fortalezcan la confianza del cliente y respalden el crecimiento sostenible de la organización.

1.3 Objetivos

ID	Objetivo SMART	Indicador de éxito	Fecha objetivo	Sponsor
OBJ-01	Diseñar e implementar en un plazo máximo de 90 días la capacidad CTI mínima viable de RataSoft, logrando que el 100% de los PIR priorizados cuenten con stakeholders definidos, KIQ asociados, fuentes identificadas y productos de inteligencia establecidos.	% de PIR completos y validados; ciclo CTI documentado.	90 días	CISO
OBJ-02	Implementar en los primeros 6 meses la operación inicial del ciclo CTI, integrando al menos 5 fuentes de inteligencia y logrando que el 90% de los productos críticos sean distribuidos dentro del SLA definido para apoyar decisiones de seguridad y riesgo.	Número de fuentes integradas; cumplimiento de SLA de productos CTI.	6 meses	CISO / Líder CTI
OBJ-03	Durante los primeros 18 meses , fortalecer la capacidad preventiva de RataSoft mediante inteligencia accionable, logrando que al menos el 80% de los productos CTI generen acciones documentadas de mitigación, detección o gestión de riesgo.	Productos CTI con acciones asociadas / total de productos CTI.	18 meses	CISO
OBJ-04	Evaluar y mejorar anualmente la madurez del programa CTI mediante un assessment basado en CTI-CMM, cerrando al menos el 50% de las brechas prioritarias identificadas durante la evaluación inicial.	Assessment CTI-CMM realizado; porcentaje de brechas cerradas.	12 meses	CISO / Líder CTI

1.4 Alcance y exclusiones

En alcance	Fuera de alcance / frontera
Unidades de negocio: Desarrollo de software, plataformas digitales, servicios entregados a clientes regulados (Banco Andino y Clínica Aurora) y áreas relacionadas con seguridad, desarrollo y operaciones.	Investigaciones o actividades no autorizadas: Vigilancia, monitoreo o recolección de información sin propósito legítimo, autorización o justificación de inteligencia.
Países / jurisdicciones: Jurisdicciones donde RataSoft opera y donde mantiene relaciones contractuales con clientes regulados, considerando requisitos legales aplicables.	Atribución pública sin revisión legal: No se realizarán declaraciones públicas sobre actores de amenaza sin validación técnica, análisis de confianza y revisión legal.
Tecnologías IT / OT / cloud: Infraestructura tecnológica, aplicaciones, APIs, repositorios de código, CI/CD, identidades, servicios cloud, endpoints y herramientas de seguridad asociadas.	Respuesta operacional propiedad de: El programa CTI no sustituye las funciones del SOC, Incident Response, DevOps o equipos operativos responsables de ejecutar cambios y remediaciones.
Tipos de inteligencia: Estratégica, operacional, táctica y técnica orientada a decisiones de negocio, gestión de riesgo, detección y protección de activos críticos.	No se realizará seguimiento individual de empleados, clientes o terceros sin fundamento legal y autorización correspondiente.

1.5 Principios rectores

- Stakeholder-first: toda capacidad se diseña desde una decisión o necesidad del consumidor.
- Risk-informed: la prioridad se determina por criticidad, exposición, probabilidad e impacto.
- Actionable: cada producto incluye implicancias, nivel de confianza y cursos de acción.
- Traceable: fuentes, transformaciones, hipótesis y decisiones quedan documentadas.
- Legal y ético: recolección, retención y difusión respetan jurisdicción, privacidad y términos de uso.
- Continuous improvement: feedback, medición y lecciones aprendidas alimentan el siguiente ciclo.

02

Gobierno y modelo operativo

Establece sponsor, responsabilidades, relaciones y mecanismos de decisión.

2.1 Estructura de gobierno

La estructura de gobierno del programa CTI asegura que las decisiones estratégicas, tácticas y operativas se encuentren alineadas con los objetivos del negocio, la gestión del riesgo y el cumplimiento normativo, promoviendo la coordinación entre las áreas responsables de producir y consumir inteligencia.

Instancia	Responsabilidad	Participantes	Frecuencia	Evidencia
Sponsor ejecutivo	Aprobar la estrategia, priorizar inversiones, asignar presupuesto, resolver bloqueos y evaluar el desempeño del programa CTI.	[CISO / CIO / CRO]	Trimestral	Actas de comité, decisiones ejecutivas y aprobación presupuestaria.
Comité CTI	Aprobar PIR/KIQ, validar productos CTI, revisar métricas, roadmap, riesgos y prioridades del programa.	Líder CTI, CISO, CTO, SOC/MSSP, AppSec, Gestión de Riesgos, Legal/DPO y Customer Success	Mensual	Scorecard ejecutivo, backlog de iniciativas y actas de reunión.
Mesa operacional	Coordinar actividades del ciclo CTI, validar indicadores, priorizar casos, compartir inteligencia accionable y dar seguimiento a acciones.	CTI, SOC/MSSP, Incident Response (IR), Gestión de Vulnerabilidades (VM), DevOps y AppSec	Semanal	Casos gestionados, acciones de mitigación, IOC distribuidos y minutas operativas.
Revisión legal y privacidad	Validar la recolección, tratamiento, almacenamiento y difusión de inteligencia que involucre datos personales, fuentes sensibles o clientes regulados.	Legal, DPO, CTI	Según el nivel de riesgo	Dictámenes legales, autorizaciones y registro de cumplimiento.

2.2 Modelo operativo

Un programa maduro gestiona stakeholders de forma dinámica y transversal. Puede operar con un equipo centralizado, federado o híbrido; la elección debe considerar escala, disponibilidad de talento, sensibilidad de las fuentes y necesidad de proximidad con las decisiones. *(DeBolt et al., 2026)*

Modelo operativo: CTI como capacidad transversal y orientada a stakeholders

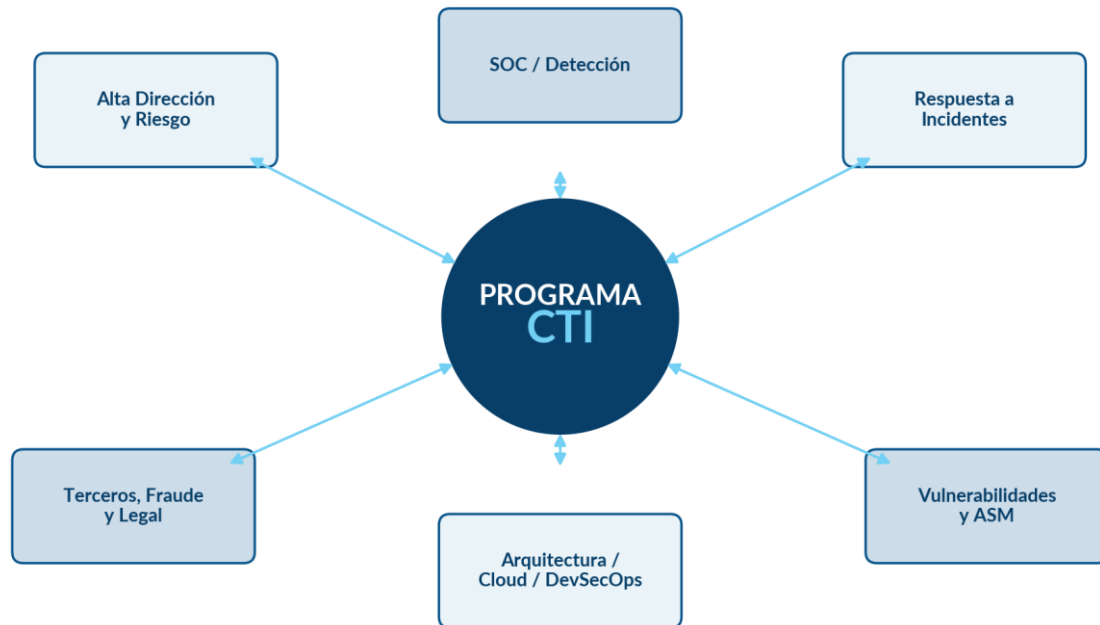


Figura 2. Modelo operativo transversal. Elaboración propia.

Justificación:

Se selecciona un modelo centralizado debido a que RataSoft se encuentra en una etapa inicial de implementación del programa CTI, cuenta con recursos humanos limitados y requiere establecer procesos, estándares y productos de inteligencia homogéneos. Este enfoque facilita el gobierno de las fuentes de inteligencia, la priorización de los PIR/KIQ y el uso eficiente del presupuesto disponible. Conforme el programa alcance un mayor nivel de madurez, podrá evaluarse la evolución hacia un modelo híbrido.

Modelo	Ventaja	Riesgo	Criterio de elección
Centralizado	Consistencia, control de fuentes y especialización	Cuello de botella y distancia del negocio	Organización mediana o etapa inicial
Federado	Proximidad a unidades y velocidad local	Duplicidad, estándares dispares	Grupos grandes y unidades autónomas
Híbrido	Gobierno central con analistas/enlaces distribuidos	Mayor complejidad de coordinación	Organización multinacional o madura

2.3 Mapa de stakeholders

Stakeholder	Decisiones soportadas	Necesidad de inteligencia	Producto / canal	Propietario relación
Directorio / CEO / Comité Ciberseguridad	Aprobar inversión, priorizar iniciativas y evaluar el riesgo estratégico.	Tendencias de amenazas, exposición organizacional, impacto en clientes y cadena de suministro.	Executive Brief trimestral / Scorecard Ejecutivo.	CISO
CISO / Gestión de Riesgos	Definir controles, priorizar riesgos, aprobar PIR/KIQ y supervisar el programa CTI.	Actores de amenaza, campañas, exposición, vulnerabilidades críticas y nivel de riesgo.	Dashboard CTI, Assessment y Threat Reports.	Líder CTI

Stakeholder	Decisiones soportadas	Necesidad de inteligencia	Producto / canal	Propietario relación
SOC / MSSP / Detección / IR	Crear detecciones, priorizar hunting y responder alertas.	IOC, TTP, campañas activas, indicadores ATT&CK y alertas tempranas.	Detection Package, IOC Feed y Flash Alerts.	Líder CTI
Incident Response (IR) / Comité Crisis	Contención, análisis y coordinación de incidentes.	Contexto del actor, infraestructura, campañas y atribución técnica.	Flash report / SITREP	Líder CTI
AppSec / Gestión de Vulnerabilidades (VM)	Priorizar remediación y reducir exposición.	Explotación, KEV, activo afectado	Vulnerability Bulletin y API Risk Report.	Líder CTI
Terceros / Fraude / Legal / DPO / Customer Success	Comunicación con clientes, cumplimiento normativo y gestión contractual.	Filtraciones, abuso de marca, fraude, exposición de datos y riesgos regulatorios.	Dossier por cliente, Brand Monitoring Report y Executive Brief.	CISO

2.4 Matriz RACI

Actividad	Sponsor	Líder CTI / CISO	Analista CTI	SOC / IR / MSSP	Riesgo / Legal / DPO	TI / Arquitectura / (AppSec / DevOps)
Aprobar estrategia y alcance	A	R	C	I	C	C
Definir y priorizar PIR	A	R	C	C	C	C
Gestionar fuentes y proveedores	C	A/R	R	C	C	C
Producir inteligencia	I	A	R	C	C	I
Ejecutar cursos de acción	I	C	C	R	C	A
Medir impacto y madurez	A	R	C	C	C	C

LEYENDA RACI

R = Responsable de ejecutar · A = Responsable final / accountable · C = Consultado · I = Informado.

2.5 Equipo, roles y competencias

Debido a la restricción de recursos de RataSoft, algunos roles CTI serán desempeñados como funciones compartidas. El CISO asumirá el liderazgo del programa y funciones estratégicas dentro de su disponibilidad de 0,5 FTE, mientras que el Security Engineer cubrirá principalmente las actividades tácticas y operativas.

Rol	Responsabilidades	Competencias mínimas	FTE / cobertura
Líder CTI / CISO	Definir la estrategia CTI, gestionar stakeholders, aprobar PIR/KIQ, supervisar la calidad de los productos y administrar el programa.	Gobierno CTI, gestión del riesgo, comunicación ejecutiva, liderazgo y toma de decisiones.	0,5 FTE (CISO)
Analista estratégico	Elaborar escenarios, analizar actores de amenaza, producir inteligencia estratégica y apoyar la toma de decisiones.	Análisis estructurado, redacción ejecutiva, gestión del riesgo, MITRE ATT&CK, OSINT.	Función asumida por Líder CTI / CISO dentro del 0,5 FTE asignado
Analista táctico/operacional	Analizar campañas, IOC, TTP, elaborar Flash Reports, Detection Packages y apoyar al SOC.	ATT&CK, SIEM, IOC, análisis de malware, threat hunting y OSINT.	0,75 FTE (Security Engineer)

Rol	Responsabilidades	Competencias mínimas	FTE / cobertura
Ingeniero de inteligencia	Gestionar la ingesta de fuentes, automatización, integraciones con SIEM, GitHub, OpenCTI/MISP y mantenimiento técnico del programa.	STIX/TAXII, APIs, scripting, automatización, integración de herramientas y gestión de datos.	0,25 FTE (DevOps) + 0,25 FTE Security Engineer
Enlace / Intelligence Liaison	Recopilar requerimientos, coordinar con stakeholders y dar seguimiento al consumo y retroalimentación de productos CTI.	Comunicación, gestión de demanda, facilitación y conocimiento del negocio.	Función asumida por Líder CTI / CISO dentro del 0,5 FTE asignado

03

Madurez y requerimientos

Convierte las prioridades del negocio en preguntas y capacidades medibles.

3.1 Evaluación de madurez

El CTI-CMM utiliza niveles CTI0 a CTI3 para describir progresión desde ausencia de prácticas hasta capacidades líderes, estandarizadas, transversales, medibles y alineadas con resultados de negocio. El modelo permite definir estado actual, estado objetivo y capacidades necesarias para cerrar brechas. (DeBolt et al., 2026)

Modelo de madurez orientativo para establecer estado actual, objetivo y brechas

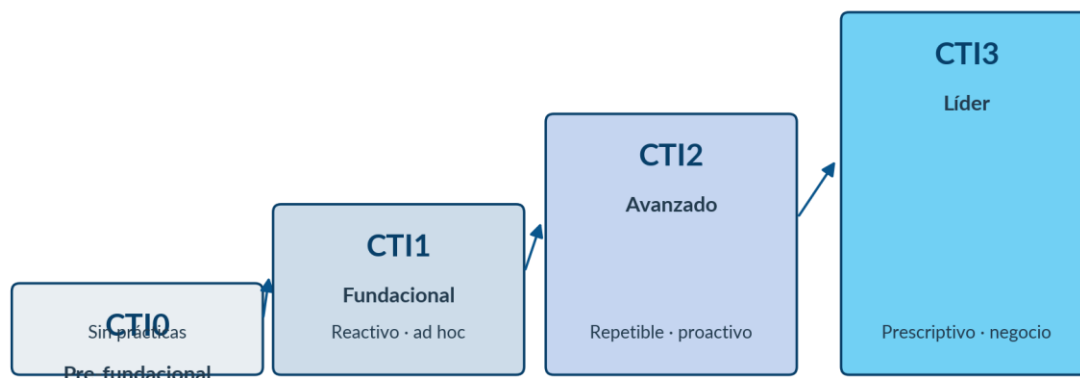


Figura 3. Niveles de madurez CTI0–CTI3. Adaptado de CTI-CMM v1.3.

Dominio CTI-CMM	Actual (0–3)	Objetivo (0–3)	Brecha	Prioridad	Evidencia
ASSET — Activos, cambios y configuración	1	2	Falta consolidar inventario de activos críticos y Crown Jewels con enfoque CTI.	Alta	Inventario DevOps, CMDB parcial, repositorios GitHub, CloudTrail.
THREAT — Amenazas y vulnerabilidades	1	3	No existe un proceso formal para PIR/KIQ, análisis de amenazas y priorización basada en inteligencia.	Alta	Incidentes phishing, KEV, vulnerabilidades, advisory de runners.
RISK — Gestión de riesgo	1	2	Riesgos técnicos identificados pero sin integración formal con CTI.	Alta	BIA, registros de riesgo, evaluaciones internas.
ACCESS — Identidad y acceso	2	3	Existen MFA y controles, pero	Alta	MFA bloqueada, credential stuffing

Dominio CTI-CMM	Actual (0-3)	Objetivo (0-3)	Brecha	Prioridad	Evidencia
			falta inteligencia continua sobre credenciales comprometidas y abuso de identidad.		Banco Andino, logs Google Workspace
SITUATION — Conciencia situacional	0	2	No existe capacidad estructurada de monitoreo de amenazas externas.	Alta	Ausencia de TIP, necesidad de fuentes CTI.
RESPONSE — Incidentes y continuidad	2	3	Existen capacidades de respuesta, pero requieren integración con inteligencia accionable.	Media	WAF, EDR, MSSP, tickets SEC/Jira.
THIRD-PARTIES — Terceros	1	2	Falta monitoreo continuo de proveedores, clientes y cadena de suministro.	Alta	Caso Banco Andino, proveedor CI/CD, dependencia externa.
FRAUD — Fraude y abuso	1	2	Existen señales de fraude, pero no un proceso formal de brand monitoring.	Media	Credential stuffing, oferta de acceso VPN, phishing.
WORKFORCE — Fuerza laboral	1	2	Falta inteligencia continua sobre riesgo humano y exposición de empleados.	Media	Phishing a desarrolladores, credenciales comprometidas.
ARCHITECTURE — Arquitectura	1	2	Falta arquitectura CTI integrada con SOC, DevOps y fuentes externas.	Alta	Ausencia de TIP, uso inicial de Jira/Confluence.
PROGRAM — Gestión del programa	0	3	No existe gobierno formal, métricas, productos ni ciclo CTI definido.	Alta	Creación del programa CTI.

3.2 Requerimientos de inteligencia

Los requerimientos deben conducir la recolección, el procesamiento y el análisis. Un PIR expresa una necesidad prioritaria de decisión; los KIQ la descomponen en preguntas respondibles y observables. Los requerimientos deben revisarse cuando cambien misión, activos, adversarios, exposición o apetito de riesgo. (Costa-Gazcón, 2021; ENISA, 2020)

PIR	Decisión asociada	Stakeholder	KIQ	Prioridad	Plazo	Criterio de cierre
PIR-01: ¿Cuál es el nivel actual de exposición de RataSoft frente a amenazas dirigidas contra sus activos críticos?	Priorizar la reducción de la superficie de ataque y fortalecer la protección de los Crown Jewels.	KIQ-01.1: CISO KIQ-01.2: CTO KIQ-01.3: SOC KIQ-01.4: CISO KIQ-01.5: CEO	KIQ-01.1: ¿Qué activos críticos (Crown Jewels) presentan mayor exposición frente a amenazas externas? KIQ-01.2: ¿Qué vulnerabilidades o debilidades afectan a los Crown Jewels y cuáles tienen evidencia de explotación activa? KIQ-01.3: ¿Existe evidencia de compromiso de credenciales, tokens o secretos asociados a RataSoft? KIQ-01.4: ¿Qué actores de amenaza tienen capacidad e intención de atacar activos similares y qué TTP utilizan? KIQ-01.5: ¿Cuál es la probabilidad de explotación considerando exposición, amenaza e impacto al negocio?	KIQ-01.1: Alta KIQ-01.2: Alta KIQ-01.3: Alta KIQ-01.4: Media KIQ-01.5: Alta	Mensual Mensual Catorcenal Mensual Mensual	K1.1: Inventario validado y activos clasificados según criticidad y nivel de exposición. K1.2: Vulnerabilidades priorizadas considerando criticidad y explotación activa. K1.3: Evidencia confirmada o descartada y acciones iniciadas. K1.4: Perfil de actores documentado y TTP mapeados. K1.5: Riesgo calculado y validado por el comité de seguridad.
PIR-02: ¿Qué amenazas emergentes podrían afectar los servicios críticos ofrecidos por RataSoft?	Priorizar controles preventivos y ajustar la estrategia de defensa ante amenazas emergentes.	KIQ-01.1: CISO KIQ-01.2: CTO KIQ-01.3: SOC KIQ-01.4: CEO KIQ-01.5: CEO	KIQ-02.1 ¿Qué campañas de amenazas están afectando actualmente al sector donde opera RataSoft? KIQ-02.2: ¿Qué vulnerabilidades críticas o zero-day recientemente divulgadas podrían impactar los servicios de RataSoft? KIQ-02.3: ¿Qué nuevas TTP están siendo utilizadas por los actores de amenaza contra organizaciones similares? KIQ-02.4: ¿Qué tendencias reportan CISA, ENISA, MITRE ATT&CK y los principales proveedores de inteligencia? KIQ-02.5: ¿Qué amenazas presentan mayor probabilidad de materializarse en los próximos seis meses?	KIQ-02.1: Alta KIQ-02.2: Alta KIQ-02.3: Media KIQ-02.4: Media KIQ-02.5: Alta	Semanal Semanal Mensual Mensual Trimestral	K2.1: Campañas identificadas, evaluadas y comunicadas a los stakeholders con su nivel de riesgo. K2.2: Vulnerabilidades priorizadas y notificadas al equipo técnico. K2.3: TTP documentadas y mapeadas a MITRE ATT&CK. K2.4: Tendencias consolidadas en un informe ejecutivo. K2.5: Escenarios priorizados y aprobados por el comité de seguridad.

PIR	Decisión asociada	Stakeholder	KIQ	Prioridad	Plazo	Criterio de cierre
PIR-03: ¿Qué actores de amenaza tienen capacidad e intención de atacar el sector donde opera RataSoft?	Priorizar el monitoreo de actores relevantes y adaptar las capacidades de detección y respuesta.	KIQ-01.1: CISO KIQ-01.2: CTO KIQ-01.3: CEO KIQ-01.4: SOC KIQ-01.5: AppSec	KIQ-03.1: ¿Qué grupos APT o actores financieros atacan organizaciones similares? KIQ-03.2: ¿Cuáles son sus motivaciones y objetivos? KIQ-03.3: ¿Qué capacidades técnicas poseen? KIQ-03.4: ¿Qué TTP utilizan con mayor frecuencia? KIQ-03.5: ¿Qué infraestructura (C2, malware, dominios, IP) utilizan en campañas recientes?	KIQ-03.1: Alta KIQ-03.2: Media KIQ-03.3: Media KIQ-03.4: Media KIQ-03.5: Alta	Mensual Mensual Mensual Mensual Continua	K3.1: Actores priorizados y perfilados. K3.2: Motivaciones documentadas y asociadas al riesgo para RataSoft. K3.3: Capacidades documentadas y evaluadas K3.4: TTP mapeadas y utilizadas para generar detecciones. K3.5: IOC validados e incorporados al SIEM/EDR.
PIR-04: ¿Qué riesgo representan las identidades, credenciales y mecanismos de acceso privilegiado de RataSoft frente a las técnicas utilizadas por actores de amenaza?	Priorizar la remediación de vulnerabilidades y la asignación de recursos de AppSec según el riesgo.	KIQ-01.1: CISO KIQ-01.2: CTO KIQ-01.3: CTO KIQ-01.4: SOC KIQ-01.5: CISO	KIQ-04.1 ¿Qué técnicas utilizan los actores de amenaza para comprometer identidades corporativas, cuentas privilegiadas y accesos cloud? KIQ-04.2: ¿Existen credenciales, tokens, API Keys o secretos expuestos públicamente o comercializados en fuentes externas? KIQ-04.3: ¿Qué cuentas, roles o privilegios representan mayor riesgo en caso de compromiso? KIQ-04.4 ¿Qué indicadores técnicos permiten detectar abuso de identidad, robo de sesión o uso anómalo de credenciales? KIQ-04.5: ¿Qué controles de autenticación, privilegios mínimos y gestión de secretos reducen el riesgo sin afectar la operación?	KIQ-04.1: Alta KIQ-04.2: Alta KIQ-04.3: Alta KIQ-04.4: Media KIQ-04.5: Media	Mensual Catorcenal Mensual Mensual Bimestral	K4.1: Técnicas identificadas y mapeadas a casos de uso de detección. K4.2: Hallazgos confirmados o descartados y plan de remediación definido. K4.3: Inventario de cuentas privilegiadas evaluado y priorizado. K4.4: Reglas de detección implementadas y validadas K4.5: Roadmap de controles aprobado e incorporado al plan de seguridad.
PIR-05: ¿Qué amenazas pueden comprometer la cadena de suministro de software de RataSoft y afectar la integridad de sus productos y servicios?	Gestionar el riesgo de proveedores, dependencias de software y servicios críticos mediante controles y evaluaciones de terceros.	KIQ-01.1: CISO KIQ-01.2: CTO KIQ-01.3: CTO KIQ-01.4: SOC KIQ-01.5: CISO	KIQ-05.1 ¿Qué actores de amenaza están atacando actualmente cadenas de suministro de software, repositorios o proveedores tecnológicos similares a RataSoft? KIQ-05.2: ¿Qué dependencias, librerías o componentes utilizados por RataSoft presentan vulnerabilidades explotables?	KIQ-05.1: Alta KIQ-05.2: Alta KIQ-05.3: Alta KIQ-05.4: Media KIQ-05.5: Media	Bimestral Mensual Mensual Bimestral Bimestral	K5.1: Actores priorizados y documentados. K5.2: Dependencias clasificadas y priorizadas. K5.3: Evaluación concluida y

PIR	Decisión asociada	Stakeholder	KIQ	Prioridad	Plazo	Criterio de cierre
			KIQ-05.3: ¿Existen riesgos asociados con repositorios, pipelines CI/CD, runners o procesos de despliegue? KIQ-05.4 ¿Qué TTP utilizan los atacantes para modificar código, insertar componentes maliciosos o comprometer procesos de desarrollo? KIQ-05.5: ¿Qué controles de seguridad generan mayor reducción de riesgo en el ciclo de desarrollo sin afectar la velocidad de entrega?			riesgos clasificados. K5.4: Técnicas documentadas y mapeadas. K5.5: Plan de endurecimiento aprobado.
PIR-06: ¿Qué vulnerabilidades representan una amenaza real para aplicaciones, APIs y servicios críticos?	Determinar la necesidad de activar procesos de respuesta, notificación regulatoria y protección de datos.	KIQ-01.1: AppSec KIQ-01.2: CTO KIQ-01.3: SOC KIQ-01.4: CISO KIQ-01.5: CTO	KIQ-06.1 ¿Qué vulnerabilidades están siendo explotadas activamente? KIQ-06.2: ¿Qué APIs presentan mayor probabilidad de abuso? KIQ-06.3: ¿Qué técnicas utilizan los atacantes contra aplicaciones similares? KIQ-06.4 ¿Qué activos podrían generar mayor impacto si son comprometidos? KIQ-06.5: ¿Cómo debe priorizarse la remediación?	KIQ-06.1: Alta KIQ-06.2: Alta KIQ-06.3: Media KIQ-06.4: Alta KIQ-06.5: Alta	Semanal Mensual Mensual Mensual Semanal	K6.1: Boletín actualizado semanalmente. K6.2: APIs clasificadas por criticidad. K6.3: Informe técnico publicado. K6.4: Activos críticos priorizados. K6.5: Backlog de remediación actualizado.
PIR-07: ¿Qué impacto podrían tener la exposición de información, el fraude y el abuso de marca sobre RataSoft y sus clientes?	Priorizar acciones de protección de marca, comunicación preventiva a clientes y mitigación de campañas de fraude.	KIQ-01.1: DPO KIQ-01.2: Legal KIQ-01.3: CISO KIQ-01.4: Customer Success KIQ-01.5: CEO	KIQ-07.1 ¿Existe evidencia de exposición o filtración de información sensible de RataSoft o sus clientes? KIQ-07.2: ¿Existen dominios falsificados o campañas de phishing que suplanten la identidad de RataSoft? KIQ-07.3: ¿Qué actores realizan campañas de fraude o abuso de marca contra organizaciones similares? KIQ-07.4: ¿Qué clientes presentan mayor exposición frente a estas amenazas? KIQ-07.5: ¿Qué acciones preventivas y de comunicación deben implementarse para reducir el impacto sobre los clientes?	KIQ-07.1: Alta KIQ-07.2: Alta KIQ-07.3: Media KIQ-07.4: Alta KIQ-07.5: Media	Continua Continua Bimestral Mensual Catorcenal	K7.1: Campañas identificadas y notificadas. K7.2: Actores perfilados. K7.3: Clientes priorizados. K7.4: Clientes priorizados según nivel de exposición y riesgo, con acciones de mitigación recomendadas y validadas por Customer Success. K7.5: Guía preventiva publicada.

3.3 Perfil de amenazas organizacional

Componente	Descripción / criterio	Resultado
Misión y procesos críticos	Servicios cuya degradación produce impacto material	RataSoft desarrolla y opera soluciones digitales para clientes regulados. Los

Componente	Descripción / criterio	Resultado
		procesos críticos incluyen disponibilidad de plataformas desarrolladas, protección de datos de clientes, continuidad de servicios SaaS/aplicaciones, seguridad del ciclo de desarrollo (CI/CD), soporte a clientes y cumplimiento de compromisos contractuales.
Crown jewels	Datos, sistemas, identidades y capacidades prioritarias	Código fuente y repositorios GitHub , pipelines CI/CD y runners, secretos y credenciales cloud, APIs y servicios expuestos, bases de datos con información de clientes, infraestructura cloud, identidades privilegiadas de desarrolladores y accesos utilizados por clientes regulados.
Superficie de ataque	Exposición externa, cloud, terceros, OT, endpoints y personas	Internet-facing APIs, aplicaciones web, repositorios privados, infraestructura cloud, herramientas DevOps, cuentas de desarrolladores, proveedores tecnológicos, MSSP, endpoints corporativos y usuarios con acceso privilegiado. No se identifican activos OT relevantes en el alcance actual.
Adversarios relevantes	Crimen organizado, actores estatales, hacktivismo, insider, fraude	Prioridad alta: ciberdelincuencia organizada , grupos dedicados a robo de credenciales, extorsión, acceso inicial y venta de accesos. Prioridad media: actores enfocados en fraude contra clientes y abuso de marca. Insider y actores estatales se consideran escenarios secundarios según el tipo de información objetivo.
Motivaciones	Financiera, espionaje, disrupción, influencia, abuso	Principalmente beneficio financiero mediante robo de credenciales, venta de accesos, fraude, ransomware o extorsión. También existe riesgo de disrupción operativa, exposición de datos de clientes y afectación reputacional frente a clientes regulados.
TTP prioritarias	Técnicas ATT&CK con plausibilidad e impacto	Phishing (T1566) contra desarrolladores, Valid Accounts (T1078) por credenciales comprometidas, Exploitation of Public-Facing Application (T1190) contra APIs/servicios expuestos, Ingress Tool Transfer (T1105) , Unsecured Credentials (T1552) , abuso de repositorios y CI/CD, y técnicas relacionadas con supply chain.
Escenarios	Cadenas de ataque plausibles vinculadas a impacto	1) Compromiso de identidad de desarrollador → acceso a GitHub → exposición de secretos → compromiso cloud 2) Explotación de API pública → acceso no autorizado → afectación de clientes regulados. 3) Compromiso de dependencia o runner CI/CD → introducción de código malicioso → afectación de aplicaciones.

Componente	Descripción / criterio	Resultado
		4) Venta de acceso o credenciales comprometidas → fraude contra clientes o infraestructura interna.

3.4 Priorización de requerimientos y casos de uso

Criterio	Peso	Escala	Puntaje
Impacto potencial en negocio	[30%]	1–5	Evaluación del impacto sobre Crown Jewels, clientes regulados, continuidad operativa y reputación.
Probabilidad / actividad adversaria	[20%]	1–5	Nivel de actividad observada, campañas vigentes, explotación conocida y capacidad del actor.
Exposición y vulnerabilidad	[20%]	1–5	Exposición pública, criticidad del activo, vulnerabilidades conocidas y controles existentes.
Urgencia de la decisión	[15%]	1–5	Tiempo disponible para tomar acción antes de materialización del riesgo.
Disponibilidad / calidad de datos	[10%]	1–5	Existencia de fuentes confiables, cobertura y posibilidad de corroboración.
Esfuerzo y costo	[5%]	1–5 inversa	Menor esfuerzo operativo y costo reciben mayor puntuación.

Fórmula de priorización

Defina la fórmula, umbrales y autoridad para resolver empates. Documente excepciones ejecutivas.

Puntaje de prioridad CTI = (Impacto × 0,30) + (Probabilidad × 0,20) + (Exposición × 0,20) + (Urgencia × 0,15) + (Calidad de datos × 0,10) + (Esfuerzo inverso × 0,05)

Ejemplo:

Si un PIR obtiene todos los criterios con puntuación 5: = (5×0.30) +(5×0.20) +(5×0.20) +(5×0.15) +(5×0.10) +(5×0.05) = **5 puntos**

Umbrales de priorización

Puntaje obtenido	Prioridad	Tratamiento
4,0 – 5,0	Crítica	Atención inmediata, generación de producto CTI prioritario y seguimiento ejecutivo
3,0 – 3,9	Alta	Incluir en backlog activo y generar inteligencia dentro del SLA definido.
2,0 – 2,9	Media	Monitoreo y análisis programado según disponibilidad.

< 2,0	Baja	Mantener como requerimiento secundario o reevaluar necesidad.
-------	------	---

Autoridad para resolver empates

Los empates de priorización serán resueltos por el Líder CTI / CISO considerando la criticidad del activo afectado, exposición actual, obligaciones contractuales con clientes y riesgo residual. En caso de afectar clientes regulados o requerir inversión adicional, la decisión será escalada al Sponsor ejecutivo.

Excepciones ejecutivas

El Sponsor ejecutivo podrá solicitar atención prioritaria fuera del orden establecido cuando exista impacto potencial sobre clientes estratégicos, exposición pública confirmada, requerimientos regulatorios o evidencia de actividad adversaria activa. La excepción deberá quedar documentada en el backlog CTI y en el registro de decisiones.

04

Ciclo de inteligencia

Define procesos repetibles desde la dirección hasta el feedback y la mejora.

4.1 Modelo de ciclo CTI

El ciclo de inteligencia comprende dirección, recolección, procesamiento, análisis, diseminación y feedback. La recolección sin capacidad de procesamiento pierde valor; la diseminación debe ajustarse a la urgencia y nivel de detalle del receptor; el feedback permite comprobar si la inteligencia fue relevante y accionable. (Costa-Gazcón, 2021; Pace, 2018)



Figura 4. Ciclo de inteligencia CTI. Elaboración propia, adaptada de literatura de inteligencia.

Fase	Entrada	Actividades mínimas	Salida / evidencia	SLA
Dirección	Riesgo, PIR, decisión	Priorizar requerimientos, validar PIR/KIQ, asignar responsables y definir criterios de colección.	Plan de colección aprobado, tareas asignadas y actualización del backlog CTI.	5 días hábiles
Recolección	Plan y fuentes	Obtener información de fuentes OSINT, comerciales e internas;	Datos recopilados, metadatos y registro de fuentes.	Continua (24x7 para fuentes

Fase	Entrada	Actividades mínimas	Salida / evidencia	SLA
		registrar evidencias y preservar trazabilidad.		automatizadas; diaria para revisión manual)
Procesamiento	Datos brutos	Normalizar, deduplicar, enriquecer, clasificar y almacenar información.	Información procesada, enriquecida y lista para análisis.	24 horas
Análisis	Información + contexto	Corroborar evidencias, aplicar técnicas analíticas estructuradas, evaluar impacto, nivel de confianza y definir cursos de acción (COA).	Productos CTI (Threat Report, Flash Alert, SITREP, Executive Brief, Detection Package, etc.).	48 horas (máximo para inteligencia táctica; estratégica según calendario
Diseminación	Producto aprobado	Distribuir la inteligencia según audiencia, clasificación TLP, canal y nivel de urgencia.	Producto entregado y acuse de recepción cuando aplique.	4 horas para alertas críticas; 1 día hábil para productos programados.
Feedback	Uso / decisión / resultado	Recopilar retroalimentación, medir utilidad, actualizar PIR/KIQ y registrar lecciones aprendidas.	Retroalimentación documentada, PIR actualizados y acciones de mejora.	Dentro de los 10 días hábiles posteriores a la emisión del producto

4.2 Plan de recolección

KIQ	Indicador / observable	Fuente	Método	Frecuencia	Responsable	Limitaciones
KIQ-01.1	Vulnerabilidades CVSS $\geq$ 9.0, vulnerabilidades KEV, activos críticos afectados	Inventario de activos, CMDB, Shodan, Censys, SecurityTrails	API feeds + análisis de vulnerabilidades	Diario	CTI / CISO	Dependencia de la actualización de los feeds y del inventario de activos.
KIQ-01.2	IP públicas, dominios, subdominios, puertos, servicios y certificados expuestos	CISA KEV, NVD, CVE, Tenable, Nessus, MITRE ATT&CK	OSINT automatizado + validación interna	Semanal	AppSec	Cobertura parcial de activos no inventariados o recientemente desplegados.
KIQ-01.3	Credenciales filtradas, tokens, API Keys, secretos expuestos	GitHub, GitGuardian, Have I Been Pwned, SIEM, EDR	Monitoreo automatizado + búsqueda OSINT	Diario	SOC	Restricciones legales y cobertura limitada del monitoreo de Dark Web.
KIQ-01.4	Técnicas ATT&CK observadas, patrones de ataque, campañas relacionadas	MITRE ATT&CK, OpenCTI, MISP, CrowdStrike, Microsoft Threat Intelligence	Correlación de eventos y análisis de logs	Continua	CTI / CISO	La atribución y las TTP pueden cambiar rápidamente entre campañas.
KIQ-01.5	EPSS, CVSS, presencia en KEV, inteligencia de amenazas	Resultados de KIQ anteriores, CVSS, CISA	API feeds + análisis de vulnerabilidades	Diario	CTI / CISO	Depende de la calidad y actualidad de la

KIQ	Indicador / observable	Fuente	Método	Frecuencia	Responsable	Limitaciones
		KEV, análisis CTI				inteligencia recopilada.
KIQ-02.1	Nuevas campañas, CVE críticos, alertas sectoriales	OpenCTI, MISP, CISA Alerts, ENISA Threat Landscape, Microsoft Threat Intelligence, CrowdStrike Intelligence	Monitoreo de reportes y feeds	Semanal	Analista CTI / Ciberinteligencia	Dependencia de la publicación oportuna de fuentes externas.
KIQ-02.2	Sectores afectados, tecnologías atacadas, tendencias	CISA KEV, NVD, CVE, VulnCheck, GitHub Security Advisories	Monitoreo de reportes y feeds	Semanal	Analista CTI / Ciberinteligencia / AppSec	Información basada en muestras públicas; puede existir sesgo de cobertura.
KIQ-02.3	Nuevas técnicas ATT&CK, malware, herramientas utilizadas	MITRE ATT&CK, ATT&CK Sightings, OpenCTI, Informes de proveedores	Monitoreo de reportes y feeds	Semanal	Analista CTI / Ciberinteligencia	Algunas campañas no son divulgadas públicamente.
KIQ-02.4	Tendencias de ataque, incremento de campañas, vectores frecuentes	CISA, ENISA, Verizon DBIR, IBM X-Force, Microsoft	Monitoreo de reportes y feeds	Semanal	Analista CTI / Ciberinteligencia	Requiere análisis periódico y corroboración entre múltiples fuentes.
KIQ-02.5	Controles recomendados, mitigaciones, detecciones sugeridas	Resultado del análisis CTI, histórico de incidentes, inteligencia externa	Monitoreo de reportes y feeds	Semanal	CTI / CISO	Las recomendaciones dependen del contexto tecnológico de RataSoft.
KIQ-03.1	Actores activos, nivel de capacidad e intención	MITRE ATT&CK, MITRE CTID, OpenCTI, MISP, CrowdStrike, Microsoft Threat Intelligence	Inteligencia OSINT + threat feeds	Mensual	Analista CTI / Ciberinteligencia	La atribución puede tener un nivel de confianza limitado.
KIQ-03.2	Motivación financiera, espionaje, extorsión, hacktivismo	Informes CTI, Mandiant, Recorded Future, CISA	Inteligencia OSINT + threat feeds	Mensual	Analista CTI / Ciberinteligencia	La motivación puede inferirse, pero no siempre confirmarse.
KIQ-03.3	Dominios, IP, C2, hosting, malware asociado	ATT&CK, MalwareBazaar, VirusTotal, informes CTI	Inteligencia OSINT + threat feeds	Mensual	Analista CTI / Ciberinteligencia	La infraestructura cambia constantemente para evadir detección.
KIQ-03.4	IOC válidos, TTP ATT&CK, malware relacionado	MITRE ATT&CK, ATT&CK Navigator, OpenCTI	Inteligencia OSINT + threat feeds	Mensual	Analista CTI / Ciberinteligencia	IOC con vida útil limitada y posible obsolescencia.

KIQ	Indicador / observable	Fuente	Método	Frecuencia	Responsable	Limitaciones
KIQ-03.5	Nivel de exposición, campañas al sector, intención del actor	VirusTotal, URLScan, GreyNoise, AlienVault OTX, MISP	Inteligencia OSINT + threat feeds	Mensual	CTI / SOC	Evaluación probabilística basada en evidencia disponible.
KIQ-04.1	Vulnerabilidades en KEV, explotación confirmada	MITRE ATT&CK, Microsoft Threat Intelligence, CISA Alerts, MISP	Monitoreo técnico + análisis AppSec	Semanal	CTI / CISO	Dependencia de la actualización de los catálogos de vulnerabilidades.
KIQ-04.2	APIs expuestas, autenticación débil, anomalías de uso	GitGuardian, GitHub, Have I Been Pwned, TruffleHog, Dark Web Monitoring	Monitoreo técnico + análisis AppSec	Semanal	CTI / CISO	Requiere telemetría completa del API Gateway.
KIQ-04.3	Técnicas ATT&CK, OWASP Top 10/API Top 10, IOC	Active Directory, Microsoft Entra ID, IAM/PAM, SIEM	Monitoreo técnico + análisis AppSec	Semanal	IAM	Información variable según la disponibilidad de casos públicos.
KIQ-04.4	Activos críticos identificados por el BIA y CMDB	SIEM, EDR, Microsoft Defender, MITRE ATT&CK	Monitoreo técnico + análisis AppSec	Semanal	SOC/MSSP	Depende de que el inventario de activos esté actualizado.
KIQ-04.5	EPSS, CVSS, criticidad del activo, explotación activa	NIST SP 800-63, CIS Controls v8, Zero Trust Guidance, Microsoft Security Baselines	Monitoreo técnico + análisis AppSec	Semanal	CTI / IAM	La priorización puede cambiar conforme evoluciona la amenaza.
KIQ-05.1	Proveedores críticos, nivel de acceso, criticidad del servicio	OpenCTI, MITRE, CISA, ENISA, Vendor Advisories	Integración con herramientas DevSecOps	Semanal	CTI / CISO	Información limitada de terceros y contratos.
KIQ-05.2	Dependencias vulnerables, librerías, paquetes, SBOM	Dependabot, GitHub Security Advisories, SBOM, SCA	Integración con herramientas DevSecOps	Semanal	CTI / AppSec	Cobertura limitada de dependencias indirectas.
KIQ-05.3	TTP Supply Chain, malware, compromisos de software	GitHub Audit Logs, CI/CD Logs, Azure DevOps, GitLab	Investigación CTI	Mensual	DevSecOps	Información especializada con disponibilidad variable.
KIQ-05.4	IOC, anomalías, incidentes reportados, accesos inusuales	ATT&CK, ATT&CK for Containers, OpenSSF	Investigación CTI	Mensual	CTI / CISO	Dependencia de la notificación por parte del proveedor.
KIQ-05.5	Controles compensatorios, segmentación, validaciones	NIST SSDF, OWASP SAMM, SLSA	Investigación CTI	Mensual	CTI / DevSecOps	Requiere coordinación entre TI, DevOps y proveedores.

KIQ	Indicador / observable	Fuente	Método	Frecuencia	Responsable	Limitaciones
KIQ-06.1	Datos personales, credenciales, propiedad intelectual, información financiera	CISA KEV, NVD, Exploit-DB, VulnCheck	Feeds STIX/TAXII + enriquecimiento	Continua	AppSec	Requiere clasificación actualizada de la información.
KIQ-06.2	Publicaciones en Dark Web, paste sites, credenciales expuestas	API Gateway Logs, OWASP API Top 10, SIEM	Monitoreo externo e investigación	Continua	AppSec	Restricciones legales y dificultad para verificar la autenticidad.
KIQ-06.3	Número y calidad de fuentes corroboradas	ATT&CK, Verizon DBIR, Threat Reports	Monitoreo externo e investigación	Continua	CTI / CISO	La confiabilidad puede variar entre proveedores.
KIQ-06.4	Calificación mediante Admiralty Code o metodología CTI	BIA, Inventario de activos, CMDB	Monitoreo externo e investigación	Continua	CTI / CISO	Existe un componente subjetivo en la evaluación analítica.
KIQ-06.5	Clientes afectados, obligaciones regulatorias, impacto contractual	EPSS, CVSS, KEV, CTI	Monitoreo externo e investigación	Continua	AppSec	Requiere participación de Legal y DPO para su evaluación.
KIQ-07.1	Registros expuestos, credenciales filtradas, datos publicados	Dark Web Monitoring, Have I Been Pwned (HIBP), OpenCTI, MISP, SIEM, DLP y registros de incidentes internos.	Monitoreo de dominios y análisis OSINT	Continua	CTI / CISO	La evidencia puede ser incompleta o difícil de corroborar.
KIQ-07.2	Dominios typosquatting, campañas phishing, certificados sospechosos	VirusTotal, URLScan, SecurityTrails, PhishTank	Monitoreo de dominios y análisis OSINT	Continua	CTI / CISO	Posibles falsos positivos y campañas de corta duración.
KIQ-07.3	Clientes afectados, nivel de riesgo, criticidad contractual	OpenCTI, ATT&CK, Informes de inteligencia	Correlación de información interna y externa	Mensual	CTI / CISO	Depende de la actualización del CRM y reportes internos.
KIQ-07.4	IOC, dominios, logos, correos fraudulentos, reglas de detección	CRM, Customer Success, CTI	Correlación de información interna y externa	Mensual	Customer Success	Requiere monitoreo continuo y ajuste de casos de uso.
KIQ-07.5	Guías, alertas, recomendaciones y avisos emitidos	Intelligence Reports, Customer Success	Correlación de información interna y externa	Mensual	CEO / Customer Success	La efectividad depende de la adopción por parte de los clientes.

4.3 Catálogo y evaluación de fuentes

La arquitectura de fuentes debe combinar información interna y externa, abierta, comercial y comunitaria. La selección debe responder a requerimientos, casos de uso, calidad y madurez; no existe una solución única para todas las organizaciones. (ENISA, 2020)

Fuente	Tipo	PIR / caso de uso	Calidad	Oportunidad	Costo	Riesgo legal	Decisión
Telemetría SIEM/EDR	Interna	PIR-01, PIR-04, PIR-06 y PIR-07. Detección de IOC, anomalías, abuso de credenciales, incidentes y evidencia para análisis CTI.	Alta	Alta	Hundido	Bajo	Mantener
CERT / ISAC	Comunidad	PIR-02 y PIR-03. Alertas tempranas, campañas emergentes, TTP y amenazas sectoriales.	4	4	Bajo	Bajo	Mantener
Proveedor CTI	Comercial	PIR-02, PIR-03, PIR-04 y PIR-05. Inteligencia sobre actores, campañas, vulnerabilidades y cadena de suministro.	5	5	Medio	Bajo	Evaluar adquisición
OSINT / repositorios	Abierta	Todos los PIR. Recolección de IOC, CVE, KEV, ATT&CK, dominios, exposición externa y enriquecimiento de inteligencia.	4	4	Bajo	Bajo]	Mantener
Dark web autorizado	Especializada	PIR-06 y PIR-07. Detección de filtraciones, credenciales comprometidas, fraude y abuso de marca.	4	5	Alto	Alto	Uso condicionado o a aprobación Legal / DPO

4.4 Procesamiento, enriquecimiento y calidad

Control	Regla / estándar	Herramienta	Propietario	Evidencia
Normalización	STIX 2.1 para intercambio de inteligencia y esquema interno para clasificación de entidades (IOC, actores, TTP, vulnerabilidades)	OpenCTI, MISP	Analista CTI	Muestra de inteligencia normalizada validada
Deduplicación	Eliminación de indicadores repetidos mediante comparación de hash, dominio, IP, fecha y fuente de origen	OpenCTI, MISP	Analista CTI	Reporte de indicadores duplicados eliminados / Tasa de duplicados
Enriquecimiento	Correlación de indicadores con información contextual: Whois, passive DNS, reputación, sandbox, MITRE ATT&CK y fuentes externas	VirusTotal, URLScan, SecurityTrails, OpenCTI	Analista CTI / SOC	Campos enriquecidos y relaciones identificadas
Scoring	Evaluación basada en relevancia, confiabilidad de la fuente, confianza de evidencia, severidad e impacto al negocio	OpenCTI, MISP, modelo interno de scoring	CISO / CTI	Modelo de priorización aprobado

Control	Regla / estándar	Herramienta	Propietario	Evidencia
TTL / expiración	Definición de vigencia de indicadores según tipo y criticidad (IOC temporales, dominios, IP, hashes, vulnerabilidades)	OpenCTI, MISP, SIEM	Analista CTI / SOC	Indicadores vigentes y expirados gestionados
Trazabilidad	Registro de fuente, fecha de obtención, transformación aplicada, analista responsable y producto generado	OpenCTI, MISP, sistema de tickets	Analista CTI	Audit log de inteligencia

4.5 Análisis, confianza y control de sesgos

El análisis de inteligencia en RataSoft deberá diferenciar entre hechos observables, supuestos analíticos y juicios de inteligencia, evitando conclusiones prematuras y reduciendo sesgos cognitivos mediante técnicas analíticas estructuradas.

El análisis debe distinguir hechos, supuestos y juicios; aplicar corroboración; expresar incertidumbre; y desafiar preconcepciones. La diversidad de perspectivas y las técnicas analíticas estructuradas reducen sesgos como confirmación, pensamiento lineal y mirror imaging. (*Costa-Gazcón, 2021*)

Los analistas CTI deberán aplicar procesos de corroboración utilizando múltiples fuentes independientes, documentar niveles de incertidumbre y evaluar hipótesis alternativas antes de emitir conclusiones.

Los principales sesgos considerados serán:

- Sesgo de confirmación: evitar buscar únicamente evidencia que confirme una hipótesis inicial.
- Pensamiento lineal: considerar que los adversarios pueden modificar tácticas y procedimientos.
- Mirror imaging: evitar asumir que los atacantes actuarán bajo la misma lógica que la organización defensora.

Nivel de confianza	Definición organizacional	Requisitos mínimos	Lenguaje autorizado
Alta	La evaluación está sustentada por evidencia suficiente, consistente y corroborada mediante múltiples fuentes independientes.	Múltiples fuentes independientes y consistentes; evidencia técnica o histórica confirmada.	“Evaluamos con alta confianza que...”
Media	Existe evidencia suficiente para considerar una hipótesis plausible, aunque permanecen brechas de información o factores no confirmados.	Evidencia parcial, fuentes confiables con limitaciones o corroboración incompleta así como evidencia plausible con brechas identificadas.	“Es probable que...”
Baja	La evaluación se basa en información limitada, no corroborada o con contradicciones relevantes que impiden una conclusión firme.	Una fuente única, Información incompleta, información no corroborada o contradictoria	“Es posible que...; confianza baja”

Técnica analítica	Cuándo usar	Salida esperada
Análisis de hipótesis competitivas	Evaluación de atribución, análisis de incidentes, identificación de causas alternativas y validación de escenarios.	Comparación de hipótesis, evidencia a favor/en contra y factores discriminantes.
Análisis de escenarios	Evaluación de riesgos estratégicos, continuidad del negocio y posibles impactos sobre servicios críticos.	Escenarios futuros, indicadores tempranos de cambio y cursos de acción recomendados (COA).
Diamond Model / Kill Chain	Análisis de campañas, infraestructura utilizada por adversarios y relación entre actor, capacidades y víctimas.	Modelo de relaciones entre actor, infraestructura, capacidades y objetivo afectado.

Nivel de confianza	Definición organizacional	Requisitos mínimos	Lenguaje autorizado
MITRE ATT&CK	Identificación de TTP, creación de detecciones, threat hunting y evaluación de controles existentes.	Mapeo de técnicas utilizadas, cobertura defensiva, brechas y prioridades de detección.	
Análisis de vínculos	Investigación de infraestructura maliciosa, cuentas comprometidas, fraude y abuso de marca.	Grafo de relaciones entre dominios, IP, cuentas, actores e indicadores.	

05

Productos y diseminación

Convierte el análisis en productos utilizables, oportunos y orientados a audiencia.

5.1 Catálogo de productos CTI

La forma del producto es parte de su valor. Para audiencias no técnicas, los productos deben ser concisos, evitar jerga, expresar impacto de negocio e incluir una recomendación. La misma inteligencia puede requerir formatos distintos según el consumidor. *(Pace, 2018)*

Producto	Nivel	Audiencia	Contenido mínimo	Frecuencia / SLA	Canal
Executive Brief	Estratégico	Directorio / C-level /CEO /CISO	Panorama de amenazas, exposición organizacional, riesgos estratégicos, decisiones recomendadas	Trimestral / ad hoc	Comité Ejecutivo / PPT / PDF / memo
Threat Landscape Report	Estratégico	CISO, CTO, Gestión de riesgos, Arquitectura	Amenazas emergentes, tendencias sectoriales, actores relevantes, escenarios futuros	Mensual	Informe PDF
Threat Intelligence Report	Estratégico-operacional	CISO, SOC, Arquitectura	Actores, TTP, infraestructura, intención, capacidad e impacto	Mensual / por evento	Informe CTI
Campaign report / Threat Actor Profile	Operacional	SOC / IR / hunting / CISO	Perfil del actor, motivación, capacidades, campañas asociadas y TTP	24–72 h	TIP / case mgmt / Informe
Exposure Report	Operacional	CISO, CTO, AppSec	Activos expuestos, credenciales filtradas, secretos comprometidos, nivel de riesgo	Semanal	Dashboard / Informe
Supply Chain Assessment	Estratégico-operacional	CTO, DevSecOps, AppSec	Riesgos de dependencias, SBOM, CI/CD, proveedores y controles recomendados	Mensual	Informe técnico
Vulnerability Bulletin	Operacional	VM / TI / riesgo / AppSec, TI, CTO	Vulnerabilidades explotadas, activos afectados, prioridad de remediación	Semanal	Ticket / dashboard
API Risk Report	Operacional	AppSec, CTO	Riesgos de APIs, abuso identificado, exposición y recomendaciones	Mensual	Informe
Detection Package	Táctico-técnico	SOC, Detection engineering	IOC, reglas Sigma/KQL, TTP ATT&CK, casos de uso y pruebas	Según backlog	Git / SIEM
Flash alert / SITREP (Situation Report)	Operacional-táctico	SOC, TI, negocio, CISO, Legal	Estado del incidente, evidencia, impacto, acciones realizadas y siguientes pasos	Por evento	Chat / correo / SOAR / Informe restringido
Brand Monitoring Report & Customer Risk Dossier	Estratégico-operacional	TPRM, fraude, legal, Customer Success, CEO	Dominios fraudulentos, phishing, abuso de marca, reputación digital, clientes afectados, nivel de exposición, impacto y acciones recomendadas	Por solicitud, mensual o por incidente	Informe restringido
Identity Risk Assessment	Estratégico-Operacional	CISO, CTO	Riesgos asociados a identidades, cuentas privilegiadas, IAM y controles recomendados	Trimestral	Informe

Producto	Nivel	Audiencia	Contenido mínimo	Frecuencia / SLA	Canal
Remediation Backlog	Operacional	CTO, AppSec	Vulnerabilidades priorizadas, responsables, plazos y estado de remediación	Semanal	Jira / Dashboard

5.2 Plantilla mínima de producto de inteligencia

Sección	Contenido obligatorio
Título y clasificación	Nombre del producto CTI, asunto, fecha de emisión, versión, destinatarios, clasificación TLP (White, Green, Amber o Red) y clasificación interna de RataSoft.
Key judgment	Resumen ejecutivo de la principal conclusión de inteligencia, expresado en lenguaje claro y orientado a la toma de decisiones. Debe responder directamente al PIR o KIQ correspondiente.
Relevancia organizacional	Identificación de los activos críticos (Crown Jewels), procesos de negocio, servicios, clientes, países y stakeholders potencialmente afectados por la amenaza o riesgo identificado.
Evidencia y análisis	Descripción de los hechos observados, fuentes utilizadas, indicadores de compromiso (IOC), TTP asociados a MITRE ATT&CK, hipótesis analizadas, brechas de información y nivel de confianza de la evaluación.
Impacto / riesgo	Evaluación del impacto potencial sobre la confidencialidad, integridad y disponibilidad de los activos, así como las posibles consecuencias para el negocio, clientes y cumplimiento regulatorio, indicando el horizonte temporal del riesgo.
Cursos de acción	Recomendaciones priorizadas para mitigar el riesgo, indicando responsable, plazo de implementación, dependencias y nivel de prioridad de cada acción.
Indicadores / anexos	IOC (IP, dominios, hashes), infraestructura maliciosa identificada, reglas de detección (Sigma/KQL/YARA cuando aplique), mapeo MITRE ATT&CK, referencias técnicas y evidencias complementarias.
Feedback solicitado	Confirmación de las decisiones adoptadas, utilidad del producto de inteligencia, acciones implementadas y necesidades de información adicionales para mejorar futuros productos CTI.

Todos los productos de inteligencia elaborados por el programa CTI de RataSoft deberán seguir esta estructura mínima para garantizar consistencia, trazabilidad y una comunicación efectiva entre los analistas de inteligencia y los diferentes consumidores (CEO, CISO, CTO, SOC, AppSec, Legal y Customer Success). La profundidad del contenido podrá variar según el tipo de producto, manteniendo siempre los elementos obligatorios definidos en esta plantilla.

5.3 Matriz de diseminación

Audiencia	Producto	Frecuencia	Sensibilidad	Canal autorizado	Confirmación / feedback
CEO / Directorio	Executive Brief	Trimestral o ad hoc	TLP: AMBER (Uso interno ejecutivo)	Comité Ejecutivo, correo cifrado, PDF	Confirmación de decisiones estratégicas y prioridades aprobadas.
CISO	Threat Assessment	Mensual o por evento	TLP: AMBER	Informe CTI, portal interno	Retroalimentación sobre utilidad para gestión de riesgos y ajustes a los PIR.
CTO / Arquitectura	Supply Chain Assessment	Mensual	TLP: AMBER	Informe técnico, repositorio interno	Validación de acciones de endurecimiento y seguimiento de remediaciones.
SOC / MSSP	Campaign Report / Threat Actor Profile	Dentro de las 24-72 horas posteriores a la identificación	TLP: AMBER + STRICT	Plataforma TIP, sistema de gestión de incidentes	Confirmación de reglas implementadas, hunting realizado e IOC validados.

Audiencia	Producto	Frecuencia	Sensibilidad	Canal autorizado	Confirmación / feedback
SOC / TI / Negocio	Flash alert / SITREP (Situation Report)	Menos de 4 horas desde la confirmación de la amenaza	TLP: AMBER	Correo, Microsoft Teams, SOAR	Confirmación de recepción y ejecución de acciones inmediatas.
Detection Engineering / SOC	Detection Package	Según backlog	TLP: GREEN	Git interno, SIEM, repositorio de reglas	Validación de reglas implementadas y resultados de pruebas.
AppSec / Gestión de Vulnerabilidades	Vulnerability Bulletin	Semanal	TLP: GREEN	Dashboard, sistema de tickets	Confirmación de vulnerabilidades priorizadas y estado de remediación.
Legal / DPO / Customer Success	Brand Monitoring & Customer Risk Dossier	Por solicitud o por incidente	TLP: AMBER	Informe restringido, correo cifrado	Confirmación de acciones de comunicación, notificaciones y seguimiento con clientes.

5.4 Gestión de solicitudes de información — RFI

Campo	Contenido
ID / solicitante	RFI-2026-001 – CISO de RataSoft
Pregunta / decisión	¿Existe evidencia de que algún actor de amenaza esté explotando vulnerabilidades o comprometiendo identidades que puedan afectar los activos críticos de RataSoft, y qué acciones deben priorizarse para reducir el riesgo?
Urgencia y fecha límite	Alta – Respuesta requerida en un plazo máximo de 72 horas .
Clasificación / distribución	TLP: AMBER – Distribución restringida al CISO, CTO, SOC, AppSec y Dirección de TI.
Alcance y supuestos	El análisis incluirá activos críticos (Crown Jewels), identidades privilegiadas, aplicaciones, APIs, infraestructura cloud y componentes de la cadena de suministro. Se considerarán fuentes internas (SIEM, EDR, IAM, GitHub, CMDB) y externas (MITRE ATT&CK, CISA KEV, OpenCTI, MISP, VirusTotal y HIBP).
Analista asignado	Analista de Cyber Threat Intelligence (CTI).
Estado / respuesta / feedback	Estado: Cerrado. Respuesta: Se entregó un <i>Threat Assessment</i> con hallazgos, nivel de confianza, activos afectados y cursos de acción priorizados. Feedback: El CISO aprobó las recomendaciones y solicitó incorporar nuevos indicadores de compromiso al SIEM y actualizar el backlog de remediación.

5.5 Feedback y ciclo de mejora

Pregunta de feedback	Escala / evidencia	Uso
¿Respondió el producto la pregunta o decisión?	Sí / parcial / no	Determinar si el PIR o KIQ fue satisfecho o requiere reformulación.
¿La información llegó a tiempo?	SLA cumplido / incumplido	Evaluar el desempeño del proceso de generación y distribución; ajustar fuentes, frecuencia o tiempos de respuesta.
¿Qué acción o decisión cambió?	Descripción de la decisión adoptada, responsable y fecha de implementación	Medir el impacto del producto CTI en la gestión del riesgo y en la toma de decisiones.

Pregunta de feedback	Escala / evidencia	Uso
¿Qué faltó o fue innecesario?	Comentarios del consumidor de inteligencia	Mejorar la estructura, profundidad, formato y contenido de futuros productos CTI.
¿Requiere seguimiento?	Sí / No. En caso afirmativo, indicar fecha objetivo y propietario de la acción	Generar un nuevo RFI, actualizar un PIR/KIQ existente o programar un nuevo producto de inteligencia.

06

Integración con la defensa y el riesgo

Define cómo CTI modifica detección, respuesta, vulnerabilidades, arquitectura y decisiones empresariales.

6.1 Integración con SOC y detección

Entrada CTI	Proceso SOC	Acción / salida	Métrica
IOC contextualizados (IP, dominios, hashes, URLs, credenciales comprometidas)	Enriquecimiento de alertas, validación y triage	Priorización de alertas, bloqueo de IOC, búsqueda retrospectiva (retrohunting) y actualización de listas de bloqueo	Precisión de detección (%) y tasa de falsos positivos
TTP identificados en campañas	Detection engineering	Creación o actualización de reglas de detección (Sigma, KQL, SIEM, EDR) y casos de uso alineados a MITRE ATT&CK	Número de técnicas ATT&CK cubiertas y nuevas reglas implementadas
Threat Profile / Threat Assessment	Threat hunting	Threat Profile / Threat Assessment	Número de hunts ejecutados y porcentaje de hunts con hallazgos
Flash Alert	Gestión y escalamiento de incidentes	Apertura de incidente, contención, bloqueo preventivo y notificación a las áreas involucradas	Tiempo de decisión (TTD) y tiempo de respuesta (MTTR)
Lecciones aprendidas (Post-Incident Review)	Mejora continua de detección	Actualización de reglas, playbooks, casos de uso y procedimientos operativos	Brechas de detección cerradas y mejora en cobertura ATT&CK

6.2 Integración con respuesta a incidentes y crisis

Momento	Aporte CTI	Consumidor	Evidencia
Preparación	Desarrollo de escenarios de amenaza, perfiles de actores, análisis de riesgos, actualización de playbooks y validación de contactos críticos.	Equipo de Respuesta a Incidentes (IR), Comité de Crisis, BCP, CISO	Threat Assessment, Executive Brief , playbooks actualizados y ejercicios de simulación.
Detección / análisis	Proporcionar contexto sobre la amenaza, IOC, infraestructura maliciosa, TTP (MITRE ATT&CK), alcance probable e inteligencia sobre campañas activas.	SOC / IR / CISO	Flash Alert, Campaign Report , IOC enriquecidos y SITREP técnico.
Contención	Recomendación de cursos de acción (COA), indicadores adicionales, tácticas de evasión del adversario y priorización de acciones de mitigación.	IR, TI, AppSec, SOC	Decisiones de contención documentadas, bloqueo de IOC, actualización de reglas de detección y playbooks.
Erradicación / recuperación	Evaluación de mecanismos de persistencia, evolución del actor, riesgo de reinfección y verificación de la eliminación de amenazas.	IR, Recuperación de Servicios, TI, CISO	Threat Assessment , informe de recuperación, criterios de cierre del incidente y validación técnica.
Post-incidente	Análisis de lecciones aprendidas, actualización del perfil del actor, revisión de PIR/KIQ, incorporación de nuevos IOC y mejora de controles de detección.	CISO, CTI, Arquitectura, Gestión de Riesgos	Informe Lessons Learned , actualización de PIR/KIQ, plan de mejora y nuevas reglas de detección implementadas.

6.3 Integración con vulnerabilidades y superficie de ataque

Factor de priorización	Pregunta CTI	Fuente	Resultado esperado
Explotación activa	¿Existe evidencia de explotación activa o campañas dirigidas que aprovechen esta vulnerabilidad?	CISA KEV, VulnCheck, CERT, Microsoft Threat Intelligence, telemetría del SIEM	Priorización inmediata de la remediación y definición del SLA correspondiente.
Relevancia del activo	¿La vulnerabilidad afecta un Crown Jewel o un activo expuesto a Internet?	CMDB, ASM (Attack Surface Management), Inventario de activos, BIA	Contextualización del impacto sobre el negocio y priorización según criticidad del activo.
Actor y sector	¿Los actores de amenaza relevantes para el sector SaaS/FinTech utilizan esta vulnerabilidad en sus campañas?	MITRE ATT&CK, OpenCTI, MISP, Vendor Reports, Threat Intelligence	Estimación de la probabilidad de explotación contextual y ajuste del nivel de riesgo.
Controles compensatorios	¿Qué controles existentes reducen la probabilidad de explotación mientras se implementa la remediación definitiva?	Arquitectura de seguridad, SIEM, EDR, WAF, documentación de controles	Definición de cursos de acción (COA) temporales y reducción del riesgo residual.
Tendencia y ventana de explotación	¿Con qué rapidez está siendo weaponizada la vulnerabilidad y cuál es la ventana estimada para su explotación?	Exploit-DB, GitHub Security Advisories, CISA KEV, OpenCTI, monitoreo autorizado de fuentes OSINT	Determinación de la urgencia de remediación, incremento del monitoreo y actualización de prioridades.

6.4 Integración con riesgo, arquitectura, terceros y fraude

Dominio	Decisión informada por CTI	Producto / evidencia	Responsable
Riesgo empresarial	Evaluar escenarios de amenaza, probabilidad de materialización, impacto al negocio y priorización de tratamientos del riesgo.	Threat Assessment, Executive Brief , actualización del Registro de Riesgos	Gestión de Riesgos CRO / CISO
Arquitectura	Definir controles de seguridad, segmentación, Zero Trust, hardening y prioridades de mejora de la arquitectura.	Threat Assessment, Threat Modeling , cobertura MITRE ATT&CK y TTP Coverage Report	Arquitectura de Seguridad / CTO
Gestión de terceros (TPRM)	Evaluar riesgos de proveedores, cadena de suministro, exposición de terceros y requisitos de seguridad contractuales.	Supply Chain Assessment, Brand Monitoring & Customer Risk Dossier , alertas de exposición	TPRM / compras / CISO
Fraude y abuso	Detectar campañas de phishing, abuso de marca, fraude contra clientes, infraestructura maliciosa y fortalecer controles antifraude.	Campaign Report, Flash Alert , IOC, análisis de infraestructura y Brand Monitoring Report	Fraude / SOC
Fuerza laboral	Priorizar campañas de concientización, identificar perfiles de alto riesgo y adaptar el contenido de capacitación según las amenazas observadas.	Threat Landscape Report , tendencias de phishing, campañas activas y recomendaciones de awareness	RR. HH. / Awareness
Legal y privacidad	Determinar obligaciones de notificación, evaluar implicaciones regulatorias y validar el tratamiento de evidencia e información sensible.	Threat Assessment, SITREP , evidencia técnica y evaluación jurídica	Legal / DPO

6.5 Threat-informed defense

Paso	Actividad	Evidencia
1. Priorizar	Seleccionar actores de amenaza, campañas y TTP relevantes para RataSoft considerando el sector, activos críticos (Crown Jewels), exposición pública y escenarios de amenaza identificados en los PIR.	Lista priorizada de adversarios, técnicas ATT&CK relevantes y escenarios de amenaza evaluados.
2. Mapear	Relacionar las técnicas y procedimientos utilizados por adversarios con activos críticos, controles existentes, fuentes de telemetría y capacidades de detección disponibles.	Matriz MITRE ATT&CK con relación entre TTP, activos, controles, fuentes de datos y brechas identificadas.
3. Detectar	Diseñar y mejorar capacidades de detección mediante reglas SIEM, EDR, analíticas de comportamiento y casos de uso alineados con las técnicas adversarias priorizadas	Backlog de detección, reglas Sigma/KQL, casos de uso SIEM/EDR y cobertura ATT&CK documentada.
4. Validar	Ejecutar ejercicios de validación mediante adversary emulation, purple team o pruebas atómicas para comprobar que los controles detectan las técnicas esperadas.	Resultados de pruebas, métricas de detección, hallazgos identificados y recomendaciones de mejora.
5. Mejorar	Cerrar brechas identificadas mediante ajustes en controles, arquitectura, reglas de detección, playbooks y actualización de PIR/KIQ según la evolución del panorama de amenazas.	Plan de remediación, actualización de controles, nuevos requerimientos de inteligencia y mejora continua del programa CTI.

07

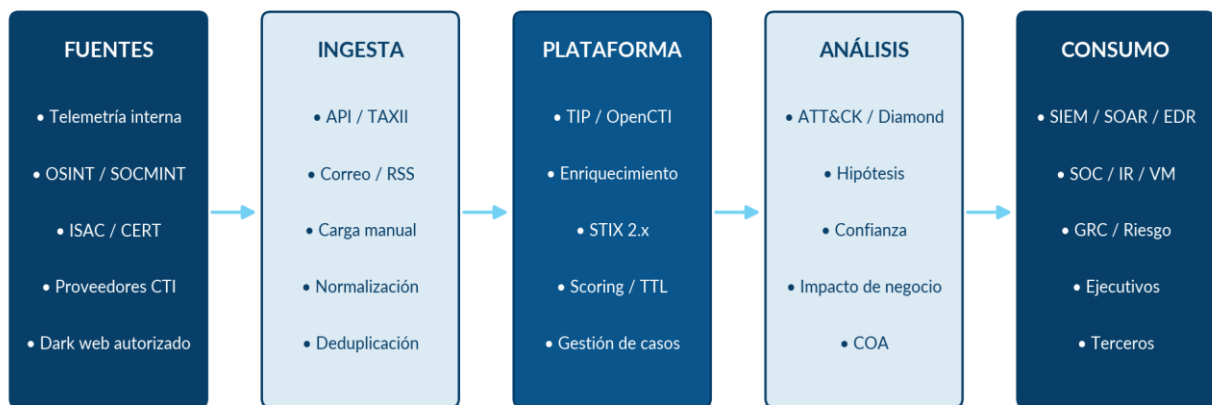
Tecnología, datos y seguridad

Define la arquitectura habilitante sin convertir la tecnología en el objetivo del programa.

7.1 Arquitectura lógica de referencia

Las herramientas deben automatizar la recolección, el procesamiento y la diseminación, preservando tiempo analítico humano. La selección tecnológica debe partir de los requerimientos, la madurez y los casos de uso, y puede combinar capacidades abiertas y comerciales. (ENISA, 2020; Pace, 2018)

Arquitectura lógica de referencia – ajustar a la tecnología y madurez de la organización



Controles transversales: acceso mínimo · clasificación · retención · trazabilidad · calidad · privacidad · auditoría

Figura 5. Arquitectura lógica CTI. Elaboración propia.

7.2 Requisitos funcionales de plataforma

Capacidad	Obligatoria	Deseable	Criterio de aceptación
Ingesta API, STIX/TAXII, correo y archivos	☒	☐	La plataforma permite integrar fuentes internas y externas mediante APIs, feeds STIX/TAXII, carga de archivos y recepción de reportes de inteligencia
Normalización, deduplicación y enriquecimiento	☒	☐	La plataforma transforma indicadores a un formato común, elimina duplicados y permite enriquecer IOC con contexto de reputación, geolocalización, WHOIS, DNS, sandbox y ATT&CK.
Gestión de entidades, relaciones y campañas	☒	☐	Permite asociar actores, infraestructura, indicadores, vulnerabilidades, víctimas y TTP para construir perfiles de amenaza y seguimiento de campañas.
Scoring, confianza, severidad y TTL	☒	☐	Permite asignar niveles de confianza, criticidad, relevancia, vigencia de indicadores y criterios de priorización basados en riesgo.

Capacidad	Obligatoria	Deseable	Criterio de aceptación
Workflow, casos, tareas y aprobaciones	☒	☐	Permite gestionar solicitudes RFI, investigaciones, asignación de responsables, seguimiento de tareas y aprobación de productos CTI.
Integración SIEM, SOAR, EDR, VM, ticketing y GRC	☒	☐	La plataforma permite enviar indicadores y contexto hacia herramientas operativas para detección, respuesta, gestión de vulnerabilidades y riesgo.
Control de acceso, auditoría, cifrado y segregación	☒	☐	Cuenta con control basado en roles (RBAC), registro de actividades, protección de información sensible y separación de accesos según clasificación TLP.
Métricas, dashboards y exportación	☐	☒	Permite crear tableros de madurez, métricas operativas, cumplimiento de SLA, cobertura ATT&CK y exportación de reportes ejecutivos.

7.3 Gobierno de datos CTI

Control	Política / estándar	Responsable	Evidencia
Clasificación y TLP	Clasificación de información basada en Traffic Light Protocol (TLP 2.0) y política interna de clasificación (Pública, Interna, Confidencial y Restringida).	CISO / CTI	Matriz de clasificación
Retención y eliminación	Política de retención de inteligencia basada en requisitos legales, regulatorios y operativos; eliminación segura conforme al ciclo de vida de la información.	CTI	Reglas de retención y registros (logs) de eliminación
Privacidad / datos personales	Cumplimiento de la Ley Federal de Protección de Datos Personales en Posesión de los Particulares (LFPDPPP) , principios de minimización de datos y tratamiento conforme a la base legal aplicable.	DPO / Legal	Evaluación de impacto y documentación de la base legal
Control de acceso	Principio de mínimo privilegio , autenticación multifactor (MFA), control de acceso basado en roles (RBAC) y segregación de funciones.	CISO / IAM	Revisiones periódicas de accesos y registros de auditoría
Calidad y linaje	Registro obligatorio de fuente, fecha de obtención, transformaciones aplicadas, analista responsable y versión del producto de inteligencia.	CTI	Registros de auditoría y trazabilidad completa
Compartición externa	Intercambio de inteligencia bajo el principio Need-to-Know , acuerdos de intercambio de información (NDA/ISA) y etiquetado mediante TLP 2.0 .	CISO / CTI	Registro de divulgación y evidencia de clasificación TLP

7.4 Proveedores, licencias y evaluación

Proveedor / solución	Caso de uso	Datos / cobertura	SLA	Costo total	Riesgo lock-in	Decisión
OpenCTI	Plataforma central de gestión y correlación de inteligencia	IOC, actores de amenaza, campañas, TTP, relaciones STIX	Comunidad / Soporte Enterprise opcional	Bajo (Open Source)	Bajo	Adoptar
MISP	Intercambio y compartición de inteligencia	IOC, STIX, TAXII, feeds de inteligencia	Comunidad	Bajo (Open Source)	Bajo	Adoptar

Proveedor / solución	Caso de uso	Datos / cobertura	SLA	Costo total	Riesgo lock-in	Decisión
VirusTotal	Reputación y enriquecimiento de indicadores	Hashes, dominios, IP, URLs, malware	SaaS	Medio	Medio	Adoptar
GitGuardian	Detección de secretos, credenciales y API Keys expuestas	Repositorios GitHub/GitLab, secretos y tokens	SaaS	Medio	Bajo	Adoptar
Microsoft Defender XDR / SIEM	Telemetría, detección y respuesta	Endpoints, identidad, correo, nube y eventos de seguridad	Empresarial	Alto	Medio	Mantener
MITRE ATT&CK	Marco de referencia para TTP y cobertura defensiva	Técnicas, tácticas y procedimientos de adversarios	NA	Sin costo	Nulo	Adoptar

08

Medición y mejora continua

Demuestra valor, identifica brechas y orienta inversiones futuras.

8.1 Modelo de medición

Las métricas deben evolucionar desde volumen y esfuerzo hacia utilidad, influencia y reducción de riesgo. El nivel líder combina medidas cuantitativas y cualitativas, las vincula con resultados y las utiliza para decidir acciones futuras. (DeBolt et al., 2026)

Categoría	Indicador	Fórmula / evidencia	Meta	Frecuencia	Propietario
Demanda	% PIR con stakeholder y decisión definidos	PIR completos / total de PIR	100 %	Mensual	Líder CTI
Oportunidad	% productos entregados dentro de SLA	Productos entregados a tiempo / Total de productos	≥ 95%	Mensual	CTI
Utilidad	% productos que generaron decisión/acción	Productos con acción documentada / Total de productos	≥ 80%	Trimestral	Stakeholder
Detección	% TTP prioritarias con detección validada	Técnicas ATT&CK cubiertas / Técnicas prioritarias	≥ 90%	Mensual	SOC
Vulnerabilidad	% de activos críticos remediados por inteligencia	Casos priorizados y remediados / Casos priorizados	≥ 85%	Mensual	Gestión de Vulnerabilidades (VM)
Calidad	Precisión de IOC y tasa de expiración	IOC verdaderos positivos / IOC operativos	≥ 90%	Mensual	CTI/SOC
Impacto	Riesgos o exposiciones reducidas mediante CTI	Riesgos mitigados / Riesgos identificados	≥ 70%	Trimestral	Gestión de Riesgos
Satisfacción	Valor percibido por stakeholder	Promedio de Encuesta (1–5) + comentario	≥ 4.5 / 5	Trimestral	Líder CTI

8.2 Scorecard ejecutivo

Indicador clave	Periodo anterior	Periodo actual	Meta	Tendencia	Comentario ejecutivo
Cobertura de amenazas prioritarias	N/A	6 de 7 amenazas prioritarias identificadas	100%	▲	Se identificaron eventos relacionados con phishing, credenciales, cadena de suministro, APIs, CI/CD y venta de accesos..
Acciones defensivas generadas	N/A	6 acciones iniciadas	≥ 90% de eventos con respuesta	▲	Se activaron controles como MFA, WAF, secret scanning, EDR y gestión de vulnerabilidades.
Tiempo a diseminación crítica	N/A	N/D	≤ 4 horas	—	El caso no proporciona tiempos de notificación entre detección y difusión.

Indicador clave	Periodo anterior	Periodo actual	Meta	Tendencia	Comentario ejecutivo
Riesgos / exposiciones reducidas	N/A	3 riesgos parcialmente mirigados	≥ 80%	▲	MFA evitó el acceso, el WAF bloqueó el escaneo y el paquete malicioso no llegó a producción.
Madurez CTI-CMM	Nivel 1	Nivel 2	Nivel 3	▲	La organización cuenta con capacidades de monitoreo y respuesta, pero aún presenta oportunidades de mejora en inteligencia y automatización.
Satisfacción de stakeholders	N/A	N/D	≥ 4.5 / 5	—	El caso no proporciona evidencia sobre encuestas o retroalimentación de los consumidores de inteligencia.

8.3 Revisión de madurez y mejora

Actividad	Frecuencia	Participantes	Salida
Revisión de PIR y stakeholders	Trimestral	CTI + consumidores de inteligencia (CEO, CISO, CTO, SOC, AppSec, Customer Success)	PIR actualizados, nuevos KIQ incorporados, requerimientos obsoletos retirados y prioridades ajustadas al riesgo del negocio.
Revisión de fuentes y proveedores	Semestral	CTI + compras + legal	Evaluación de cobertura, costo, calidad, integración y decisión de mantener, renovar, sustituir o retirar proveedores y fuentes de inteligencia.
Assessment CTI-CMM	Anual	CTI + líderes de dominio (SOC, AppSec, DevSecOps, Riesgo)	Evaluación de madurez, identificación de brechas, nivel objetivo y backlog de iniciativas de mejora del programa CTI.
Lecciones aprendidas de incidentes	Por incidente mayor	Equipo de Respuesta a Incidentes (IR) + CTI + Gestión de Riesgos	Actualización de perfiles de amenaza, reglas de detección, TTP mapeadas, playbooks y cursos de acción (COA) derivados del análisis post-incidente.
Revisión ejecutiva de valor	Trimestral	Sponsor Ejecutivo + Comité de Seguridad	Evaluación del desempeño del programa CTI, cumplimiento de KPIs, retorno esperado de la inversión (ROI) y definición de prioridades estratégicas para el siguiente periodo.

La revisión periódica del programa CTI permitirá asegurar que los requerimientos de inteligencia, las fuentes de información, los productos generados y las capacidades analíticas permanezcan alineados con la evolución del panorama de amenazas y con las necesidades estratégicas de RataSoft. Este proceso de mejora continua contribuirá al incremento gradual de la madurez del programa y al fortalecimiento de la capacidad de la organización para anticipar, detectar y responder a amenazas cibernéticas.

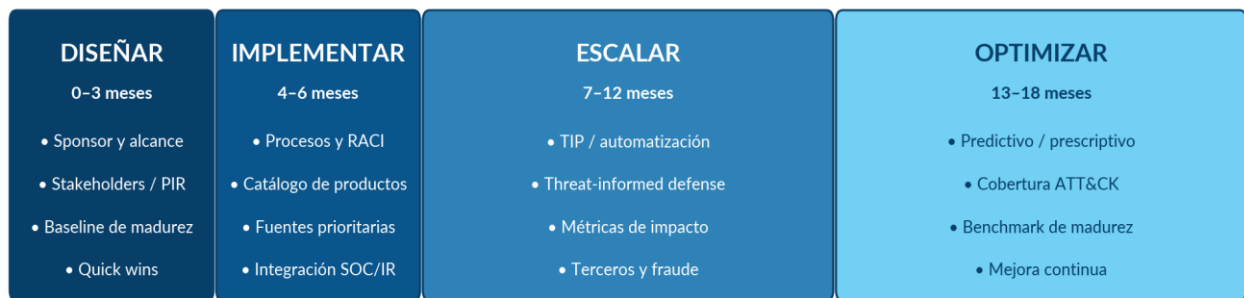
09

Roadmap, recursos y riesgos

Transforma el diseño en una secuencia de capacidades financiadas y verificables.

9.1 Roadmap de implementación

Roadmap de implementación — ejemplo editable



Cada fase debe cerrarse con evidencia, decisión de gobierno y actualización del backlog de capacidades.

Figura 6. Roadmap referencial de 18 meses. Ajustar al baseline y prioridades.

ID	Iniciativa	Fase	Responsable	Inicio	Fin	Dependencias	Criterio de cierre	Estado
INI-01	Diseñar e implementar el programa CTI (gobierno, stakeholders, PIR, KIQ, procesos y políticas)	Diseñar	CISO / Líder CTI	Mes 1	Mes 3	Patrocinio ejecutivo y definición de Crown Jewels	Programa CTI aprobado, PIR/KIQ validados y modelo de gobierno	Planeado
INI-02	Implementar la plataforma CTI e integrar fuentes internas y externas (OpenCTI, MISP, SIEM, feeds de inteligencia)	Implementar	Líder CTI / SOC / Infraestructura	Mes 4	Mes 9	Finalización de INI-01	Plataforma operativa, fuentes integradas y primeros productos CTI	Planeado
INI-03	Escalar las capacidades analíticas y operativas (MITRE ATT&CK, Threat Hunting, automatización, playbooks y métricas)	Escalar	CTI / SOC / AppSec	Mes 10	Mes 15	Finalización de INI-02	Cobertura de TTP prioritarias, KPIs implementados y procesos de hunting	Planeado
INI-04	Optimizar el programa mediante evaluación de madurez, mejora continua y automatización avanzada	Optimizar	CISO / Líder CTI	Mes 16	Mes 18	Finalización de INI-03	Assessment CTI-CMM completado, roadmap actualizado y plan de mejora continua aprobado.	Planeado

9.2 Plan de recursos y presupuesto

Componente	Año 1	Año 2	Supuesto / unidad	Responsable
Personas / FTE	0,5 CISO + 1 Security Engineer + 0,25 DevOps + MSSP	Se mantiene o se incorpora 1 Analista CTI según caso de negocio	Recursos disponibles según caso; sin contratación dedicada durante el piloto	CISO
Plataforma TIP / licencias	OpenCTI o MISP (piloto) / Jira-Confluence como alternativa inicial	Consolidación de TIP seleccionado	Implementación incremental, priorizando soluciones Open Source	CISO / CTI
Fuentes y servicios CTI	OSINT, CISA KEV, MITRE ATT&CK, VirusTotal Community, HIBP, SecurityTrails (básico)	Incorporación de fuentes comerciales si se justifica	Se priorizan fuentes gratuitas durante la fase inicial	Líder CTI
Integraciones / automatización	Integración con SIEM, GitHub, Jira y Microsoft Defender	Automatización mediante STIX/TAXII y playbooks	Se aprovechan herramientas existentes antes de adquirir nuevas plataformas	Security Engineer
Capacitación / certificaciones	Formación básica en CTI, ATT&CK y OpenCTI/MISP	Especialización del equipo	Capacitación progresiva durante la implementación	CISO
Comunidades / ISAC / eventos	Participación en CERT/CSIRT, comunidades CTI e ISAC del sector	Continuidad y fortalecimiento de la participación	Priorización de comunidades gratuitas o de bajo costo	Líder CTI
Contingencia	Reserva dentro del presupuesto aprobado	Ajuste según evaluación anual	Utilizada únicamente para necesidades no previstas o incorporación de nuevas fuentes	CISO
TOTAL	USD 55,000	Definido según resultados del piloto y aprobación del Directorio	Conforme a las restricciones presupuestarias del caso	Directorio / CISO

9.3 Riesgos del programa

ID	Riesgo	Causa	Impacto	Prob.	Nivel	Tratamiento	Dueño
R-01	Falta de adopción de stakeholders	Los consumidores pueden percibir CTI como una función técnica adicional y no como un habilitador de decisiones de negocio.	Productos de inteligencia sin uso, baja generación de acciones defensivas y pérdida de valor del programa.	Media	Alto	Definir PIR/KIQ orientados a decisiones, involucrar stakeholders desde el diseño y medir utilidad de productos CTI.	CISO / Líder CTI
R-02	Sobrecarga por datos y feeds	Incorporación excesiva de fuentes sin criterios de calidad, priorización ni consumidores definidos.	Aumento de falsos positivos, mayor carga operativa y dificultad para identificar amenazas relevantes.	Alta	Alto	Implementar criterios de selección de fuentes, scoring, control de calidad, TTL de indicadores y priorización basada en PIR.	Líder CTI
R-03	Dependencia de proveedor	Adopción de plataformas	Incremento de costos, dificultad	Media	Medio	Priorizar estándares abiertos (STIX/TAXII),	CISO / Compras

ID	Riesgo	Causa	Impacto	Prob.	Nivel	Tratamiento	Dueño
		comerciales sin considerar portabilidad de datos, estándares abiertos o plan de salida.	para cambiar herramientas y dependencia tecnológica.			evaluar MISP/OpenCTI y exigir criterios de salida antes de adquirir soluciones.	
R-04	Riesgo legal / privacidad	[Recolección de información sensible, monitoreo de fuentes externas o uso de dark web sin validación legal previa.	Incumplimiento regulatorio, exposición de datos personales y riesgos contractuales con clientes.	Media	Alto	Aplicar gobierno de datos CTI, clasificación TLP, minimización de datos y revisión Legal/DPO para fuentes sensibles.	DPO / Legal
R-05	Rotación / falta de competencias	Equipo reducido (0,5 CISO, 1 Security Engineer, 0,25 DevOps) y limitada disponibilidad de especialistas CTI.	Dependencia de personas clave, retrasos en análisis y dificultad para escalar capacidades.	Media	Alto	Capacitación progresiva, documentación de procesos, apoyo MSSP y definición de operación mínima viable.	CISO

9.4 Dependencias y supuestos

Tipo	Descripción	Propietario	Fecha de validación	Estado
Dependencia	Disponibilidad de información de activos críticos, inventario tecnológico y clasificación de Crown Jewels para priorizar requerimientos de inteligencia.	CISO / Infraestructura	Inicio del programa (Mes 1)	Pendiente
Dependencia	Acceso a telemetría y registros de seguridad existentes (SIEM, EDR, WAF, GitHub, CloudTrail, Google Workspace) para correlación y análisis CTI.	Security Engineer / MSSP	Mes 1	En validación
Dependencia	Integración inicial con herramientas existentes y evaluación de plataforma TIP (MISP/OpenCTI) o uso temporal de Jira/Confluence.	Security Engineer / CTI	Mes 3	Pendiente
Dependencia	Disponibilidad del MSSP para apoyo en monitoreo, validación de indicadores y operación inicial del programa CTI.	CISO	Mes 1	En validación
Dependencia	Aprobación del presupuesto anual de USD 55.000 para capacidades mínimas, fuentes e integración del programa CTI.	Directorio / CISO	Mes 1	Pendiente
Supuesto	Los stakeholders definidos (CEO, CTO, CISO, SOC, AppSec, Legal y Customer Success) participarán en la validación de PIR/KIQ y consumo de productos CTI.	CISO	Mes 1	Asumido
Supuesto	Las herramientas existentes pueden proporcionar información suficiente para iniciar el piloto de 90 días sin una TIP comercial completa.	Security Engineer	Mes 1	Asumido
Supuesto	El programa puede iniciar con los recursos disponibles: 0,5 CISO, 1 Security Engineer, 0,25 DevOps y soporte MSSP limitado.	CISO	Mes 1	Asumido
Supuesto	Las fuentes externas de inteligencia seleccionadas cumplen requisitos legales, de trazabilidad y privacidad antes de ser incorporadas.	Legal / DPO	Mes 2	Asumido
Supuesto	Los equipos de desarrollo aceptarán controles preventivos cuando CTI pueda demostrar impacto mediante evidencia y priorización de riesgo.	CTO / Líder CTI	Mes 3	Asumido

9.5 Criterios de aprobación y entrada en operación

- ☐ Sponsor, alcance, RACI y presupuesto aprobados.
- ☐ PIR/KIQ priorizados y vinculados con stakeholders.
- ☐ Procesos del ciclo documentados y responsables entrenados.
- ☐ Fuentes y herramientas evaluadas legal, técnica y económicamente.
- ☐ Productos, SLA, clasificación y canales de difusión definidos.
- ☐ Integraciones mínimas con SOC, IR, vulnerabilidades y riesgo probadas.
- ☐ Métricas baseline y mecanismo de feedback en operación.

Aprobación final

Rol	Nombre y cargo	Campo	Valor
Elaborado por	Arnoldo Treviño Ceja / Analista CTI / Ciberinteligencia	Fecha	[27-07-2026]
Revisado por	Isaac Martínez Cossio / CISO / Responsable CTI	Fecha	[28-07-2026]
Aprobado por	María Magdalena González Álvarez / CEO / Director General	Fecha	[29-07-2026]

A

Anexos operativos

Formatos editables para ejecutar y evidenciar el programa.

A.1 Registro maestro de PIR y KIQ

PIR ID	Necesidad / decisión	Stakeholder	KIQ	Prioridad	Fuentes	Producto	Estado	Revisión

A.2 Formulario de RFI

Campo	Valor
ID RFI	
Solicitante / unidad	
Pregunta y decisión requerida	
Contexto y alcance	
Fecha límite / urgencia	

Campo	Valor
Clasificación / distribución	
Analista asignado	
Respuesta / producto	
Acción adoptada	
Feedback / cierre	

A.3 Evaluación de fuente de inteligencia

Criterio	Pregunta	Puntaje 1-5	Evidencia
Relevancia	¿Responde a PIR y casos de uso prioritarios?		
Confiabilidad	¿Historial, metodología y transparencia son adecuados?		
Corroboración	¿Puede validarse con fuentes independientes?		
Oportunidad	¿Llega dentro de la ventana de decisión?		
Cobertura	¿Cubre geografía, sector, tecnologías y actores?		
Accionabilidad	¿Permite detectar, bloquear, priorizar o decidir?		
Integrabilidad	¿API, STIX/TAXII, formatos y licencias son utilizables?		
Legal / privacidad	¿Existe base legal, términos y retención aceptables?		
Costo total	¿Valor, esfuerzo de operación y salida son sostenibles?		

A.4 Perfil de actor o campaña

Campo	Contenido
Nombre / alias	
Tipo / motivación	
Sectores y geografías	
Objetivos / victimología	
Capacidades y herramientas	
TTP MITRE ATT&CK	
Infraestructura / IOC	
Actividad reciente	
Relevancia organizacional	
Nivel de confianza	
Cursos de acción	
Fuentes y fecha de corte	

A.5 Plantilla de alerta rápida

Sección	Contenido
CLASIFICACIÓN / TLP	
ASUNTO / SEVERIDAD	
QUÉ ESTÁ OCURRIENDO	
POR QUÉ ES RELEVANTE	
ACTIVOS / UNIDADES POTENCIALMENTE AFECTADOS	
ACCIONES INMEDIATAS	
INDICADORES / TTP	
NIVEL DE CONFIANZA Y BRECHAS	
PROPIETARIO / PRÓXIMA ACTUALIZACIÓN	

A.6 Registro de IOC y ciclo de vida

IOC	Tipo	Fuente	Confianza	Severidad	Primera vista	Última vista	TTL	Acción	Estado

A.7 Registro de acciones derivadas de CTI

ID	Producto / hallazgo	Acción	Propietario	Fecha límite	Estado	Evidencia	Resultado / riesgo

A.8 Checklist de revisión de producto

- ☐ El key judgment responde al PIR/KIQ.
- ☐ Distingue hechos, supuestos y juicios.
- ☐ Incluye nivel de confianza y brechas.
- ☐ La relevancia organizacional está explícita.
- ☐ Las fuentes están trazadas y clasificadas.
- ☐ Los IOC/TTP están validados y vigentes.
- ☐ Incluye cursos de acción priorizados.
- ☐ El lenguaje y extensión son adecuados a la audiencia.
- ☐ La distribución y clasificación fueron revisadas.
- ☐ Se definió cómo obtener feedback y medir la acción.

A.9 Autoevaluación CTI-CMM resumida

Dominio	CTI0	CTI1	CTI2	CTI3	Evidencia / observación
ASSET	☐	☐	☐	☐	
THREAT	☐	☐	☐	☐	
RISK	☐	☐	☐	☐	
ACCESS	☐	☐	☐	☐	
SITUATION	☐	☐	☐	☐	
RESPONSE	☐	☐	☐	☐	
THIRD-PARTIES	☐	☐	☐	☐	
FRAUD	☐	☐	☐	☐	
WORKFORCE	☐	☐	☐	☐	
ARCHITECTURE	☐	☐	☐	☐	
PROGRAM	☐	☐	☐	☐	

A.10 Glosario mínimo

Término	Definición de trabajo
CTI	Inteligencia contextualizada sobre adversarios, amenazas y TTP para apoyar decisiones y acciones.
PIR	Requerimiento prioritario de inteligencia vinculado con una decisión crítica.
KIQ	Pregunta clave que descompone un PIR en elementos respondibles.
RFI	Solicitud formal de información o análisis dirigida al programa CTI.
IOC	Indicador técnico asociado potencialmente a actividad maliciosa.
IOA	Indicador de comportamiento o actividad que evidencia intención o ejecución.
TTP	Tácticas, técnicas y procedimientos utilizados por un adversario.
COA	Curso de acción recomendado para reducir riesgo o responder.
TIP	Plataforma de inteligencia de amenazas.
STIX/TAXII	Estándares para representar e intercambiar información de amenazas.
TLP	Protocolo para indicar límites de distribución de información.
Threat profile	Caracterización de amenazas plausibles según intención, capacidad, objetivos y severidad.

R

Referencias

Fuentes metodológicas en formato APA 7 utilizadas para estructurar la plantilla.

Referencias

DeBolt, M., Connor, C., Beckwith, N., Bruggink, G.-J., Dennis, N., Doyle, J., Holland, J., Mohr, B., Fokker, J., Hamilton, C., Holvoet, K., Mollema, M., Perez Palma, A., Proehl, L., Schwartz, K., Small, S., Suver, J., Fernandez, C., Vansickle, A., ... Taylor, L. (2026). Cyber Threat Intelligence Capability Maturity Model (Version 1.3). CTI-CMM.

European Union Agency for Cybersecurity. (2020). Cyber Threat Intelligence Overview: ENISA Threat Landscape.

Costa-Gazcón, V. (2021). Practical Threat Intelligence and Data-Driven Threat Hunting: A hands-on guide to threat hunting with the ATT&CK framework and open source tools. Packt Publishing.

Pace, C. (Ed.). (2018). The Threat Intelligence Handbook: A practical guide for security teams to unlocking the power of intelligence. CyberEdge Group.

National Institute of Standards and Technology. (2016). Guide to Cyber Threat Information Sharing (NIST Special Publication 800-150). U.S. Department of Commerce.

MITRE. (s. f.). MITRE ATT&CK. <https://attack.mitre.org/>

Open Source Research Society. (2020). The Cyber Intelligence Analyst's Cookbook: Volume 1—A primer for open source intelligence collection and applied research.

FIN

Cierre documental

Conservar evidencia de aprobación, revisión, distribución y retiro de versiones anteriores.

Registro de distribución

Liste destinatarios, clasificación, fecha, medio y confirmación de recepción.

Destinatario	Clasificación	Fecha	Medio	Confirmación de recepción
Comité CTI	TLP:AMBER	31/07/2026	Confluence	Confirmada
SOC / IR / MSSP	TLP:GREEN	31/07/2026	Confluence / Teams	Confirmada
Legal / DPO	TLP:AMBER	31/07/2026	Correo corporativo	Confirmada
Sponsor Ejecutivo (CISO)	TLP:AMBER	31/07/2026	Confluence / Correo corporativo	Confirmada

Decisiones de aprobación

Registre condiciones, excepciones, financiamiento y fecha de entrada en vigor.

Aprobación del programa: Se aprueba la implementación del Programa CTI con enfoque incremental conforme al roadmap de 18 meses.]

Excepción: El monitoreo de Dark Web que involucre datos personales requerirá autorización previa de Legal y DPO.

Financiamiento: Se aprueba un presupuesto máximo de USD 55,000 para el Año 1, sujeto al cumplimiento de hitos del roadmap.

Entrada en vigor: El programa entrará en operación una vez cumplidos los criterios mínimos de aprobación y validación establecidos en el documento.

ESTADO DEL DOCUMENTO

Vigente desde: 31/07/2026 · Próxima revisión: 31/01/2027 · Propietario: Líder CTI / CISO · Repositorio oficial: Confluence Corporativo – Repositorio de Gobierno de Ciberseguridad